

GIJO AS — 제품 소개 자료 (v2.3.0)

한 명의 보안담당자가 여러 명 몫을 해내도록.

쏟아지는 보안 정보를 AI 에이전트가 **자동으로 엮어** 처리하는 온프레미스 보안 운영 플랫폼.

*본 자료의 모든 수치·예시·스크린샷은 실제 구동해 뽑은 **실측 백데이터**입니다(서버 자동화 테스트 **720개** 통과).*

*스크린샷은 실제 제품 화면(HTML/CSS)을 실측 서버 응답으로 렌더링한 것입니다 — 목업이 아닙니다.
(`screenshots/` 폴더)*

1. 왜 필요한가 — 보안담당자의 현실

기업 보안담당자는 **항상 인원이 부족**한데, 처리해야 할 일과 받는 정보는 계속 늘어납니다.

현실의 고충	무엇이 힘든가
보안제품 운영·관리	패치·메뉴 확인·장애 대응·발견 문제 전달을 사람이 일일이 추적
쏟아지는 보안 정보	제품 로그, CTI(위협 인텔), 취약점 스캔 결과가 따로따로 도착
정보 간 대조가 수작업	"이 위협이 우리 어느 자산에?", "이 자산 문제가 어느 서비스에?"를 눈으로 매칭
반복되는 보고	임원·팀장 보고서, KPI를 매번 손으로 취합
AI 보안까지 추가	이제 AI 모델 자산·공급망까지 관리 대상

핵심 문제: 개별 데이터는 있는데 **서로 연결이 안 되어**, 담당자가 그 연결을 머리로 대신하고 있음.

2. GIJO AS 한 줄 정의

보안 특화 **Agent AI 팀 + 로컬 LLM**이 담당자의 업무를 대신 수행하고,
흩어진 보안 정보를 자동으로 상관(correlate)시켜 "지금 무엇이 위험한지"를 바로 보여줍니다.
모든 데이터·AI가 **폐쇄망(온프레미스)** 안에서만 돕니다 — 데이터가 외부로 나가지 않습니다.

3. 핵심 가치 3가지

① 자동 상관관계 — "정보를 엮어주는" 레이어

개별 사일로(자산·CTI·점검·컴플라이언스)를 자동으로 연결합니다.

CTI 위협 → 영향받는 내부 자산 → 영향받는 업무 서비스
스캔 취약점 → 승인 검토 → SBOM 반영

② 온프레미스 Agent AI — 데이터 주권

8종 보안 에이전트가 로컬 GPU의 LLM으로 작동. 외부 API·클라우드 없이 폐쇄망 완결.

③ 지속 학습 거버넌스 — 쓸수록 똑똑해짐

RAG(장기 기억) + 헤르메스 폐쇄형 학습 루프로 실제 대화를 학습에 반영. 점검·승인은 감사 추적으로 관리.

4. 주요 기능 (업무 중심)

4.1 🗣️ 에이전트 AI 팀 + 복합 지시

목적: 자연어로 지시하면 보안 에이전트 팀이 알아서 협업 처리.

8종 고정 에이전트(실측):

에이전트	역할	추천 로컬 LLM
오케스트레이터	작업 분배·결과 취합	Qwen2.5 7B
스캔	정적분석 실행 (ModelScan)	Foundation-Sec 8B
침투테스트	익스플로잇 검증	Lily Cybersecurity 7B
분석	우선순위 판단·설명	Qwen2.5 7B
SBOM	SBOM 생성·정리	ZySec 7B
CTI	딥웹·다크웹 감시	Foundation-Sec 8B
리포트	내부 보고서 작성	Qwen2.5 7B
모델 진화	보안 특화 LLM 학습	Hermes 3

GIJO 합성 모델: 보안 특화 LLM을 SLERP로 합성해 운영할 수 있습니다. 이 배포는 Qwen2.5-7B 2종을 합성한 `gijo-main-orchestrator` (한국어·지시따르기 강점)를 오케스트레이션 주력으로 사용합니다.

복합 지시(오케스트레이션): 여러 작업을 한 문장으로.

실측 — 지시: `"CTI 영향 자산 스캔하고 리포트까지"`
→ 자동 계획: ① **스캔(대상=CTI 영향 자산 자동 해석)** → ② **리포트 작성** (2단계 복합 실행)

각 단계는 협업 로그에 실시간 표시되고, 스캔 결과가 리포트로 이어집니다.

모니터링

대시보드

보안 분석

작업 세션

보안 업무

AI 자산

취약점 관리

위협 인텔리전스

보안 운영

리포트-컴플라이언스

AI

AI 어시스턴트

AI 지식-모델

AI 견고성

시스템

로그

설정

에이전트 AI

LLM 합성

LLM 가이드

에이전트 AI

여러 보안 특화 LLM 에이전트가 역할을 나눠 협업하고, 작업을 지시하면 팀이 알아서 처리합니다

에이전트 설정

+ 에이전트 추가

예: fraud-detect-llm 취약점 전체 재스캔하고 우선순위 정리해서 리포트까지 작성해줘

▶ 에이전트 팀에게 지시하기

전체 에이전트

6

오늘 생성된 작업

117

지금 작업 중

0

완료된 작업

117

우리 팀 — 보안 에이전트 로스터

각 에이전트는 역할에 맞는 전용 모델을 사용합니다. Security Orchestrator가 작업을 나누면 Scan → Analyze 결과를 GUIO Agent가 사내 지식으로 부연하고 Report Agent가 보고서로 정리하며, TI Agent는 CTI 위협을 상시 모니터링해 영향 자산을 알립니다

Security Orchestrator

모니터링

작업 분배 · 결과 취합

지시를 해석해 Scan → Analyze → Report 순으로 작업을 나눠 맡기고, 각 단계 결과를 취합해 최종 응답으로 정리합니다.

gijo-main-orchestrator

추천: Qwen2.5 7B Instruct 약 4.7GB

적용

지시 이해와 한국어 리우딩 정확도가 좋아 작업 분배/의도 판단/결과 취합에 적합. 더 빠른 응답이 급하면 llama 3.2 3B로 교체하세요.

Scan Agent

대기중

조기 데이터 해석 · 자산 반영

업로드스캔(ModelScan) 결과로 나온 모델 취약점을 위협 관점에서 해석/요약하고 자산 finding으로 반영합니다. 결과는 Analyze Agent와 GUIO Agent로 이어집니다.

merged-illy-gijo-loop-ai-securityllm (실행중)

추천: Foundation-Sec 8B 약 4.9GB

적용

업로드스캔(ModelScan) 결과로 나온 모델 취약점을 위협 관점에서 해석/요약하는 데 강합니다.

Analyze Agent

대기중

AI 지식-모델 관리 · 우선순위 판단

기억 학습(RAG) 문맥로지 학습 루프 등 AI 지식 모델 관리를 담당하고, 스캔 finding의 우선순위를 판단합니다. 학습 데이터셋 Q&A 생성도 이 에이전트 담당입니다.

merged-illy-gijo-loop-ai-securityllm (실행중)

추천: Qwen2.5 7B Instruct 약 4.7GB

적용

우선순위 판단과 메모리은 언어에 설명 품질이 좋습니다. 기억학습(RAG) 문맥로지 관리와 학습 데이터셋 Q&A 생성도 이 에이전트 담당입니다.

Report Agent

대기중

내부 보고서 작성 · 결과 레포팅

작업 결과를 내부 보고서 문서로 정리합니다. 파이프라인 마지막 단계에서 스캔 분석 부연 결과를 받아 보고서를 만듭니다.

전역 모델 따름

추천: Qwen2.5 7B Instruct 약 4.7GB

적용

한국어 보고서 문제/서식 품질이 가장 좋아 내부 보고서/결과 레포팅에 적합합니다.

TI Agent

모니터링

위협 인텔리전스 · CTI 모니터링

딥웹 다크웹 CTI 피드 구독 기반으로 유출정보/위협을 모니터링합니다. 위협 인텔 텍스트를 자산 인벤토리(자산명,컴포넌트,CVEAI-BOM)와 대조해 영향 자산을 자동 매칭해 알립니다.

전역 모델 따름

추천: Foundation-Sec 8B 약 4.9GB

적용

딥웹다크웹 CTI 피드의 영문 위협 정보를 보안 관점에서 해석/요약하는 데 강합니다. 자산 매칭 자체는 규칙 엔진(CTI+자산 대조)이 수행합니다.

GUIO Agent

모니터링

영어 해석 · 사내 부연(사내 지식)

Scan/Analyze 결과로 나온 용어를 사내 지식베이스 근거로 해석하고 실제 사례를 부연합니다. 복합 지시에서 스캔 분석이 끝나면 자동 투입됩니다.

merged-illy-gijo-loop-ai-securityllm (실행중)

추천: Qwen2.5 7B Instruct 약 4.7GB

적용

스캔분석 결과에 나온 용어를 사내 자료 근거로 해석하고 사례를 부연하는 데 한국어 통칭/지시/머리가 좋습니다(영어/그라운드팅에 적합).

터미널 — 협업 · LLM 실행작 로그

에이전트 협업 이벤트와 로컬 LLM 실행작(추론 임베딩 모델 로드/스왑)을 시간순으로 스트리밍합니다. 각 추론의 모델 토큰 수 생성 속도(tok/s)는 llama.cpp 실행지입니다. llama-server 자체 stdout/stderr는 좌측 "로그" 메뉴에서 확인할 수 있습니다.

[오류 11:25:23] [Security Orchestrator] 추론 요청

[오류 11:25:24] orchestrator → orchestrator: 도구 실행: remediation({"topic":"사내 보안 상담 챗봇"})

[오류 11:25:24] [Security Orchestrator] gijo-main-orchestrator · 응답 완료 · 1608+27토큰 · 0.5s

[오류 11:25:24] [Security Orchestrator] 추론 요청

[오류 11:25:24] [Security Orchestrator] gijo-main-orchestrator · 응답 완료 · 1754+20토큰 · 0.3s

[오류 11:25:24] 임베딩 서버 · 1개 임베딩 · 0.0s

[오류 11:25:24] [Security Orchestrator] 추론 요청

[오류 11:25:28] [Security Orchestrator] gijo-main-orchestrator · 응답 완료 · 6239+294토큰 · 115 tok/s · 3.9s

[오류 11:25:28] orchestrator → orchestrator: 지시 처리: "사내 보안 상담 챗봇 취약점 조치 절차 알러지"

[오류 11:25:28] orchestrator → orchestrator: 원로: 사내 보안 상담 챗봇 (ai-secbot-01)의 취약점 조치 절차는 다음과 같습니다: 1. **최신 패치 적용**: - AI-BOM Qwen2.5-7B-Instruct의 최신 버전으로 업데이트해야 합니다.

[오류 11:25:28] orchestrator → 세션: ● [사내 보안 상담 챗봇 · 상태] 사내 보안 상담 챗봇 (ai-secbot-01)의 취약점 조치 절차는 다음과 같습니다: 1. **최신 패치 적용**: - AI-BOM Qwen2.5-7B-Instruct의 최신 버전으로 업데이트해야 합니다. 이는 보안 취약점을 해결하고 최신 보안

[오류 11:26:00] 세션 → orchestrator: ● [사내 보안 상담 챗봇 · 상태] 리포트 가능해?

[오류 11:26:00] [Security Orchestrator] 추론 요청

[오류 11:26:01] [Security Orchestrator] gijo-main-orchestrator · 응답 완료 · 1811+77토큰 · 1.1s

[오류 11:26:01] [Security Orchestrator] 추론 요청

[오류 11:26:01] orchestrator → report: 작업 할당: "레포트 가능해?"

[오류 11:26:01] [Security Orchestrator] gijo-main-orchestrator · 응답 완료 · 1006+12토큰 · 131 tok/s · 0.3s

[오류 11:26:01] 임베딩 서버 · 1개 임베딩 · 0.0s

[오류 11:26:01] [Report Agent] 추론 요청

[오류 11:26:08] report → orchestrator: 작업 완료: 가능합니다. AI 보안 상담 챗봇 (ai-secbot-01)의 취약점 조치 절차와 관련 리포팅을 제공하겠습니다. ### AI 보안 상담 챗봇 (ai-secbot-01) 취약점 조치 리포트 **1. 최신 패치 적용** - **취약점**: AI-BOM Qwen2.5-7B-Instruct의 견고성 미흡점 - **조치**: 최신 버전으로 업데이트하여 보안 취약점을 해결하고 최신 보안 패치를 포함하도록 합니다. - **근거**: KISA AI 보안 위협 대응 매뉴얼 (2026.7) **2. 설정 강화** - **취약점**: 설정이 약하거나 불필요한 기능, 권한이 남아 있습니다. - **조치**: 챗봇의 설정을 강화하여 불필요한 기능과 권한을 제거합니다. 특히 챗봇 내부 시스템에 접근할 수 있는 권한이 과도하지 않도록 확인합니다. - **근거**: KISA AI 보안 위협 대응 매뉴얼 (2026.7) **3. 접근 통제** - **취약점**: 챗봇의 접근이 제한적으로 이루어지지 않습니다. - **조치**: 챗봇의 접근을 엄격히 제한합니다. 필요한 사용자만 챗봇을 사용할 수 있도록 인증 절차를 강화하고, 접근 권한을 최소화합니다. - **근거**: KISA AI 보안 위협 대응 매뉴얼 (2026.7) **4. 모니터링 및 로깅** - **취약점**: 모니터링과 로깅이 부족하여 이상 행위가 탐지되지 않습니다. - **조치**: 챗봇의 활동을 모니터링하고, 접근 로그를 정기적으로 검토합니다. 이상 행위가 발견될 경우 즉시 조치를 취합니다. - **근거**: KISA AI 보안 위협 대응 매뉴얼 (2026.7) **5. 교육 및 인식** - **취약점**: 서비스 임직원들이 취약점에 대한 인식이 부족합니다. - **조치**: 서비스 임직원에게 AI 보안 챗봇의 취약점과 관련된 교육을 제공합니다. 정기적인 보안 인식 훈련을 실시하여 임직원의 보안 의식을 높입니다. - **근거**: KISA AI 보안 위협 대응 매뉴얼 (2026.7) 이러한 조치를 통해 AI 보안 상담 챗봇 (ai-secbot-01)의 취약점을 최소화하고, 안전한 환경을 유지할 수 있습니다. --- **결론**: 위의 조치를 통해 AI 보안 상담 챗봇의 취약점이 대폭 줄어듭니다. 그러나 정기적인 모니터링과 업데이트가 필요합니다.

에이전트별 브레인 모델

동작된 에이전트가 실제로 참조하는 모델 ID 목록

Security Orchestrator

gijo-main-orchestrator

Scan Agent

merged-illy-gijo-loop-ai-securityllm

Analyze Agent

merged-illy-gijo-loop-ai-securityllm

GUIO Agent

merged-illy-gijo-loop-ai-securityllm

AI 엔진 상태

llama-server · 1개 상주

merged-illy-gijo-loop-ai-securityllm · 8080

HuggingFace 모델 검색 · 불러오기

도움

보안 특화 오픈소스 모델을 검색해 로컬로 내려받습니다. 쉘 받아야 할지 모르겠다면 ? 도움(추천 LLM 가이드)에서 용도별 추천 모델을 확인하세요.

예: cybersecurity, WhiteRabbitNeo, Foundation-Sec

검색

검색어를 입력하고 검색 버튼을 눌러주세요.

[오후 11:26:08] orchestrator → 세션: ● [사내 보안 상담 챗봇 - 상태] 가능합니다. AI 보안 상담 챗봇 (ai-secbot-01)의 취약점 조치 절차와 관련 리포팅을 제공하겠습니다. ### AI 보안 상담 챗봇 (ai-secbot-01) 취약점 조치 리포트 **1. 최신 패치 적용** - **취약점**: AI-BOM

[오후 11:26:08] ● [Report Agent] gijo-main-orchestrator · 응답 완료 · 3725+703토큰 · 121 tok/s · 6.6s

[오후 11:27:50] 세션 → orchestrator: ● [사내 보안 상담 챗봇 - 상태] 사내 보안 상담 챗봇 레드팀 점검해줘

[오후 11:27:50] ● [Security Orchestrator] 주문 요청

[오후 11:27:51] orchestrator → orchestrator: 도구 실행: threats({"limit": "5"})

[오후 11:27:51] ● [Security Orchestrator] gijo-main-orchestrator · 응답 완료 · 2019+17토큰 · 0.5s

[오후 11:27:51] ● [Security Orchestrator] 주문 요청

[오후 11:27:52] ● [Security Orchestrator] gijo-main-orchestrator · 응답 완료 · 2484+130토큰 · 1.2s

[오후 11:27:52] 임베딩 · 임베딩 서버 연결 실패

[오후 11:27:52] ● [Security Orchestrator] 주문 요청

[오후 11:27:57] orchestrator → orchestrator: 지시 처리: "사내 보안 상담 챗봇 레드팀 점검해줘"

[오후 11:27:57] orchestrator → orchestrator: 완료: ### 레드팀 점검 요약 ##### 1. **악성 패키지 위협** - **위협**: 악성 패키지 - bge-m3 임베딩 모델 배포 패키지에 악성코드 삽입 사례 보고 - **해당 자산**: 사내 보안 상담

[오후 11:27:57] ● [Security Orchestrator] gijo-main-orchestrator · 응답 완료 · 4742+579토큰 · 119 tok/s · 5.4s

[오후 11:27:57] orchestrator → 세션: ● [사내 보안 상담 챗봇 - 상태] ### 레드팀 점검 요약 ##### 1. **악성 패키지 위협** - **위협**: 악성 패키지 - bge-m3 임베딩 모델 배포 패키지에 악성코드 삽입 사례 보고 - **해당 자산**: 사내 보안 상담 챗봇 (ai-secbot-01)

[오후 11:49:14] 임베딩 서버 · 1개 임베딩 · 0.1s

[오후 11:49:15] gijo-main-orchestrator · VRAM 확보 위해 내림: gijo-main-orchestrator

[오후 11:49:15] merged-lily-gijo-loop-ai-securityllm · 모델 로드 중 (포트 8080)

[오후 11:49:15] merged-lily-gijo-loop-ai-securityllm · 모델 준비 완료 (포트 8080)

[오후 11:49:15] [Analyze Agent] 주문 요청

[오후 11:49:16] [Analyze Agent] gijo-main-orchestrator · 응답 완료 · 1464+102토큰 · 114 tok/s · 1.9s

실시간 협업 현황

지우기

에이전트 간 작업 위임 · ● 로컬 LLM 주문 실행 (WebSocket 실시간 수신 — 모델 토큰 생성 속도 실행)

orchestrator → 세션 ● [사내 보안 상담 챗봇 - 상태] ### 레드팀 점검 요약 ##### 1. **악성 패키지 위협** - **위협**: 악성 패키지 — bge-m3 임베딩 모델 배포 패키지에 악성코드 삽입 사례 보고 - **해당 자산**: 사내 보안 상담 챗봇 (ai-secbot-01)

orchestrator → orchestrator 완료: ### 레드팀 점검 요약 ##### 1. **악성 패키지 위협** - **위협**: 악성 패키지 — bge-m3 임베딩 모델 배포 패키지에 악성코드 삽입 사례 보고 - **해당 자산**: 사내 보안 상담

orchestrator → orchestrator 지시 처리: "사내 보안 상담 챗봇 레드팀 점검해줘"

orchestrator → orchestrator 도구 실행: threats({"limit": "5"})

세션 → orchestrator ● [사내 보안 상담 챗봇 - 상태] 사내 보안 상담 챗봇 레드팀 점검해줘

orchestrator → 세션 ● [사내 보안 상담 챗봇 - 상태] 가능합니다. AI 보안 상담 챗봇 (ai-secbot-01)의 취약점 조치 절차와 관련 리포팅을 제공하겠습니다. ### AI 보안 상담 챗봇 (ai-secbot-01) 취약점 조치 리포트 **1. 최신 패치 적용** - **취약점**: AI-BOM

작업 완료: 가능합니다. AI 보안 상담 챗봇 (ai-secbot-01)의 취약점 조치 절차와 관련 리포팅을 제공하겠습니다. ### AI 보안 상담 챗봇 (ai-secbot-01) 취약점 조치 리포트 **1. 최신 패치 적용** - **취약점**: AI-BOM, Open2.5.7B-Instruct의 경계성 미정점 - **주의**: 최신 버전으로 업데이트하여 보안 취약점을 해결하고 최신 보안 패치

모니터링

◆ 대시보드

🔍 보안 분석

보안 업무

◇ AI 자산

🕒 취약점 관리

△ 위협 인텔리전스

🔴 보안 운영

📄 리포트-컴플라이언스

AI

● AI 어시스턴트

🌸 AI 지식 모델

🛡️ AI 견고성

시스템

📄 로그

⚙️ 설정

에이전트 AI

LLM 합성

LLM 가이드

📖 추천 LLM 가이드

GIJO AS에서 쓰기 좋은 로컬 LLM을 용도별로 정리했습니다. 설명을 보고 다운로드를 누르면 로컬에 받아지고, 에이전트 카드의 모델 드롭다운에서 선택할 수 있습니다.

- 모두 **GGUF** 형식이라 로컬(lama.cpp)에서 바로 돌립니다. 다운로드는 **Q4_K_M** 양자화된 한 개만 받습니다(용량-품질 균형).
- 7-88는 약 **4~5GB**라 및 분 걸릴 수 있어요. 진행 상황은 좌측 **로그** 메뉴에서 실시간으로 볼 수 있습니다.
- 여러 모델을 받아두면 에이전트마다 다른 모델을 배정해 **동시에** 굴릴 수 있습니다(VRAM 여유 안에서 자동 관리).
- 카드의 📦 **추천 에이전트** 배치는 그 모델이 어느 AI 팀 에이전트에 잘 맞는지 표시합니다 — **에이전트 AI** 화면에서 카드마다 바로 [받기][적용]도 할 수 있어요.

🛡️ 보안 특화 LLM

침해사고 대응-취약점 분석-보안 개념을 이미 학습한 모델. 보안 담당 에이전트의 두뇌로 바로 쓰기 좋습니다.

Lily Cybersecurity 7B 7B 보안 특화

사이버보안 일반 Q&A-사고대응-개념 설명에 특화된 채팅 모델 출신. (GIJO 기본 채팅 모델은 자체 gijo-main-orchestrator입니다.)

QuantFactory/Lily-Cybersecurity-7B-v8.2-GGUF

약 4.4GB

✓ 설치됨

ZySec 7B (SecurityLLM) 7B

보안 운영-정책-컴플라이언스 문서 이해에 강합니다. 리포트/가버너스 계열 에이전트에 적합.

QuantFactory/SecurityLLM-GGUF

약 4.4GB

✓ 설치됨

Foundation-Sec 8B 8B Cisco

위협 분석-보안 추론용 파운데이션 모델(Cisco Foundation AI). 분석-CTI 에이전트 후보.

추천 에이전트 Scan Agent TI Agent

mrademacher/Foundation-Sec-8B-GGUF

약 4.9GB

✓ 설치됨

📖 파인튜닝 베이스 LLM

우리 문서로 학습(파인튜닝)시켜 문제-판단을 각인시킬 때 쓰는 범용 베이스. 학습이 잘 먹고 자료가 많은 모델을 골랐습니다.

Hermes 3 (Llama 3.1 8B) 8B

학습루프 베이스

헤르메스 학습 루프의 확정 베이스. 지시 따르기-구조화 출력이 뛰어나 자기학습 루프에 적합합니다. 실제 학습은 HF 질본(NousResearch/Hermes-3-Llama-3.1-8B)으로, 이 GGUF는 학습 전 베이스 응답 확인용.

NousResearch/Hermes-3-Llama-3.1-8B-GGUF

약 4.9GB

✓ 설치됨

Llama 3.1 8B Instruct 8B

가장 널리 쓰이는 파인튜닝 베이스. 한국어 포함 다국어와 도구 사용이 안정적입니다.

bartowski/Meta-Llama-3.1-8B-Instruct-GGUF

약 4.9GB

✓ 설치됨

Qwen2.5 7B Instruct 7B

지시 따르기-한국어 품질이 좋아 파인튜닝 후 실무 응답이 매끄럽습니다.

추천 에이전트 Security Orchestrator

Analyze Agent Report Agent GUO Agent

bartowski/Qwen2.5-7B-Instruct-GGUF

약 4.7GB

✓ 설치됨

Phi-3.5 mini 3.8B 정량 베이스

작지만 추론이 좋아 GPU 여유가 적을 때 파인튜닝 베이스로 쓰기 좋습니다.

bartowski/Phi-3.5-mini-instruct-GGUF

약 2.4GB

다운로드

📖 지식 관리(RAG)에 강한 LLM

장기 기억(문서 검색) 결과를 잘 활용하려면 긴 컨텍스트와 요약력이 필요합니다. 검색용 임베딩 모델도 여기 있습니다.

Qwen2.5 14B Instruct 14B 롱컨텍스트

128K 토큰 컨텍스트. 많은 문서를 넣고 근거 기반으로 답하게 할 때 강합니다(VRAM 넉넉할 때).

bartowski/Qwen2.5-14B-Instruct-GGUF

약 9GB

다운로드

Qwen2.5 7B Instruct 7B 롱컨텍스트

128K 컨텍스트를 가벼운 비용으로. 일상적인 RAG 응답에 균형이 좋습니다.

추천 에이전트 Security Orchestrator

Analyze Agent Report Agent GUO Agent

bartowski/Qwen2.5-7B-Instruct-GGUF

약 4.7GB

✓ 설치됨

BGE-M3 (임베딩) 임베딩 임베딩

장기 기억 검색에 쓰는 임베딩 모델. GIJO에 기본 내장되었으며, 교체-재배치용으로 받을 수 있습니다.

gpustack/bge-m3-GGUF

약 0.4GB

✓ 설치됨

⚡ 가벼운 LLM

빠른 응답-저사양 여러 모델 동시 상주가 필요할 때. 분류/라우팅 같은 가벼운 작업에 딱 맞습니다.

Llama 3.2 3B 3B

작은 크기에 품질이 좋아 빠른 응답용으로 인기. 여러 개를 동시에 돌리기 좋습니다.

bartowski/Llama-3.2-3B-Instruct-GGUF

약 2GB

다운로드

Qwen2.5 3B 3B

한국어가 준수한 경향 모델. 요약-분류 같은 보조 작업에 적합합니다.

bartowski/Qwen2.5-3B-Instruct-GGUF

약 2GB

✓ 설치됨

Llama 3.2 1B 1B

초경량. 의도 분류-라우팅처럼 아주 빠른 판단이 필요한 곳에.

bartowski/Llama-3.2-1B-Instruct-GGUF

약 0.8GB

다운로드

Qwen2 0.5B 0.5B 초경량

가장 가벼운 테스트-개발용. 파이프라인 점검이나 저 사양 데모에 쓰입니다.

Qwen/Qwen2-0.5B-Instruct-GGUF

약 0.4GB

다운로드

4.2 🎯 CTI ↔ 내부 자산 자동 매칭 *(핵심 차별점)*

목적: "이 위협이 우리 어느 자산에 영향?"을 자동으로.

CTI 위협의 대상 텍스트를 자산의 구체적 식별자(컴포넌트·CVE·모델명)와 대조합니다.

실측 — 수집 위협 5건 중 4건이 자산에 매칭, 영향 자산 3곳:

위협 (target)	심각도	→ 영향 자산	매칭 근거
Qwen2.5 오픈웨이트 모델 가중치 변조 공급망 위협	주의	사내 보안 상담 챗봇	qwen2
bge-m3 임베딩 배포 패키지 악성코드 삽입	긴급	사내 보안 상담 챗봇	bge
KoBERT 분류 모델 대상 프롬프트 인젝션 캠페인	주의	문서 민감도 분류 AI	kobert
IsolationForest 이상탐지 우회 PoC 공개	정보	이상행위 탐지 엔진	isolationforest
(다크웹 계정 유출 — 무관)	정보	*(매칭 없음, 정상 제외)*	—

담당자의 눈 대조 작업을 없앴. 무관한 위협은 오탐 없이 걸러냄.

모니터링

◆ 대시보드

🔒 보안 분석

🗨️ 작업 세션

보안 업무

◇ AI 자산

🔗 취약점 관리

△ 위협 인텔리전스

📁 보안 운영

📄 리포트-컴플라이언스

AI

🗨️ AI 어시스턴트

🔴 AI 지식-모델

🛡️ AI 견고성

시스템

📄 로그

⚙️ 설정

위협 인텔리전스

딥웹 · 다크웹 CTI 피드 구독 기반 유출정보 · 위협 모니터링

+ 피드 구독 추가

연동된 CTI 벤더

1

탐지 내역

55

긴급 탐지

1

영향받는 내부 자산

5

🔴 내부 자산에 영향을 주는 위협

CTI ↔ 자산 자동 매칭

위협 인텔의 대상 텍스트를 자산 인벤토리(자산명-컴포넌트-CVE-AI-BOM)와 대조해 영향 자산을 자동으로 찾습니다. 담당자의 눈 대조 작업을 대신합니다.

긴급 bge-m3 임베딩 모델 배포 패키지에 악성코드 삽입 사례 보고

성품(대모)

악성 패키지

영향 자산 1 → 사내 보안 상담 챗봇 · bge

주의 Qwen2.5 오픈웨이트 모델 가중치 변조 공급망 위협 경향

성품(대모)

위협 캠페인 · 공급망

영향 자산 1 → 사내 보안 상담 챗봇 · qwen2

주의 KoBERT 기반 한국어 분류 모델 대상 프론트엔드 인젝션 캠페인

성품(대모)

프론트엔드 인젝션

영향 자산 1 → 문서 민감도 분류 AI · kobert

정보 Botnet Analysis: A Product-Grade Threat for the AI Service Era

LevelBlue OTX

위협 인텔 Pulse

영향 자산 1 → 192.168.219.98 · product

정보 Contagious Interview malware in SVG images: DPRK campaign

LevelBlue OTX

위협 캠페인 · Contagious Interview

영향 자산 1 → 192.168.219.98 · svg_images

정보 Behind the Refund: From GST Phishing to Remcos RAT Through a Multi-Stage .NET Infection Chain

LevelBlue OTX

위협 인텔 Pulse

영향 자산 1 → 192.168.219.98 · through_net_chain

정보 ClickFix Campaign Generated Via AI Delivers SmartRAT

LevelBlue OTX

위협 인텔 Pulse

영향 자산 1 → 192.168.219.98 · generated

정보 ACR Stealer: Two observed intrusion chains amid increased threat activity

LevelBlue OTX

위협 인텔 Pulse

영향 자산 1 → 192.168.219.98 · increased_two

정보 Novel Starland RAT and bespoke WLDR C2 implant deployed in financially motivated campaign

LevelBlue OTX

위협 캠페인 · UAT-11795

영향 자산 1 → 192.168.219.98 · deployed

정보 The Patch Wars have begun

LevelBlue OTX

위협 캠페인 · UAT-11795

영향 자산 1 → 192.168.219.98 · have

정보 The TTF Trap: A Global Campaign of a Low-Detection Lua Loader

LevelBlue OTX

위협 인텔 Pulse

영향 자산 1 → 192.168.219.98 · detection_low_global_loader

정보 Spirals: New Stealthy Ransomware Deployed Against Asian IT Company

LevelBlue OTX

위협 인텔 Pulse

영향 자산 1 → 192.168.219.98 · deployed_against

정보 ClickLock Stealer: Paste Once, Lose Everything

LevelBlue OTX

위협 캠페인 · ClickLock Dev

영향 자산 1 → 192.168.219.98 · once_dev_paste

정보 Attackers Weaponize Microsoft Teams Relays to Stay Hidden

LevelBlue OTX

위협 캠페인 · DragonForce

영향 자산 1 → 192.168.219.98 · microsoft_attackers

정보 Potemkin Loader & RMMPProject The Anatomy of a ClickFix Attack

LevelBlue OTX

위협 인텔 Pulse

영향 자산 1 → 192.168.219.98 · loader

정보 Gamers beware: malicious wallpapers on Steam found stealing accounts

LevelBlue OTX

위협 인텔 Pulse

영향 자산 1 → 192.168.219.98 · found_malicious

정보 Unpacking the AsyncAPI npm supply chain compromise and import-time payload delivery

LevelBlue OTX

위협 인텔 Pulse

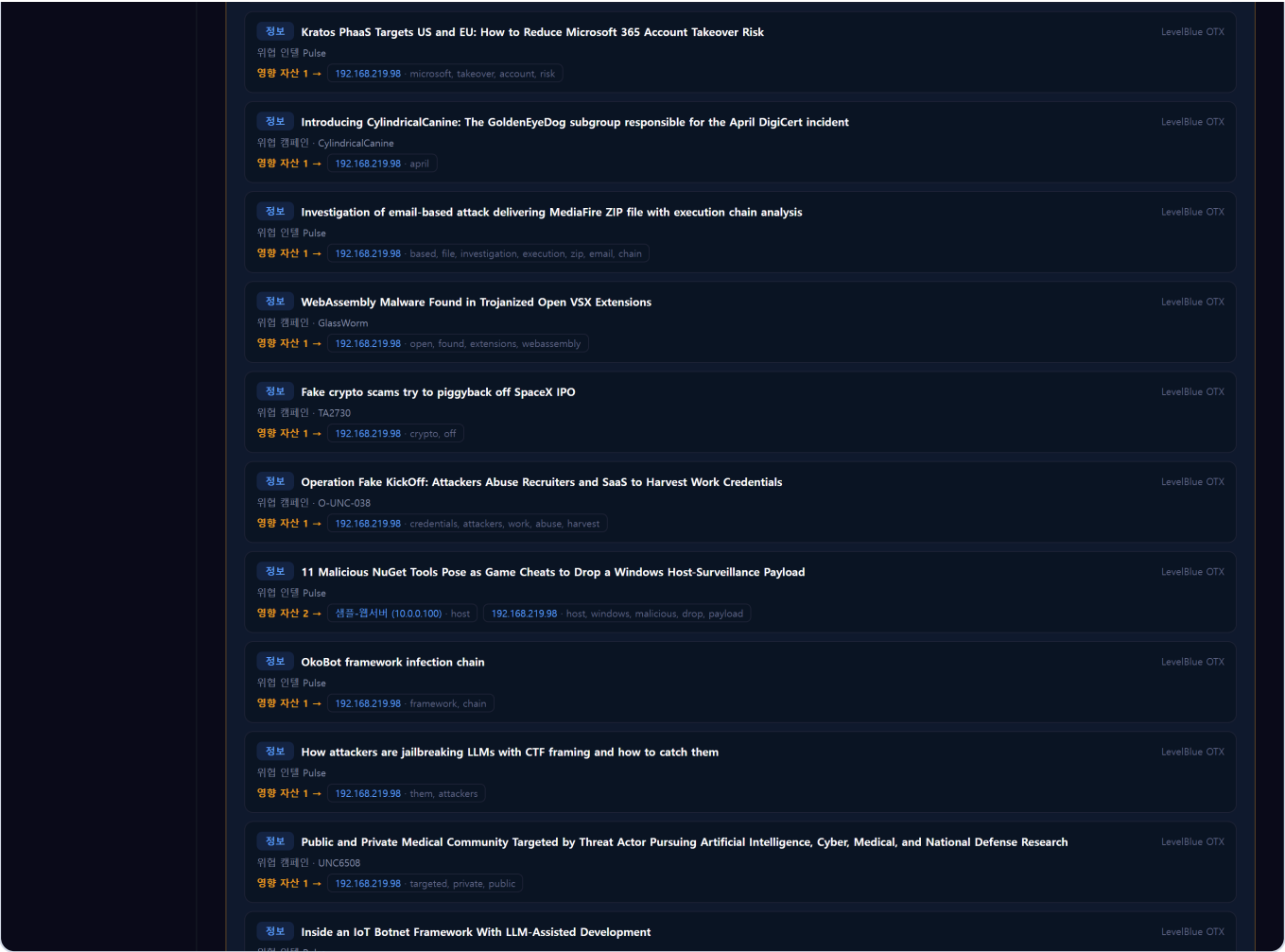
영향 자산 1 → 192.168.219.98 · time_compromise_payload_chain

정보 TELEPUZ: a modular MaaS malware spreading via CLICKFIX-VIDAR chains

LevelBlue OTX

위협 인텔 Pulse

영향 자산 1 → 192.168.219.98 · modular



4.3 🔗 서비스 영향도 — 자산 → 업무 서비스

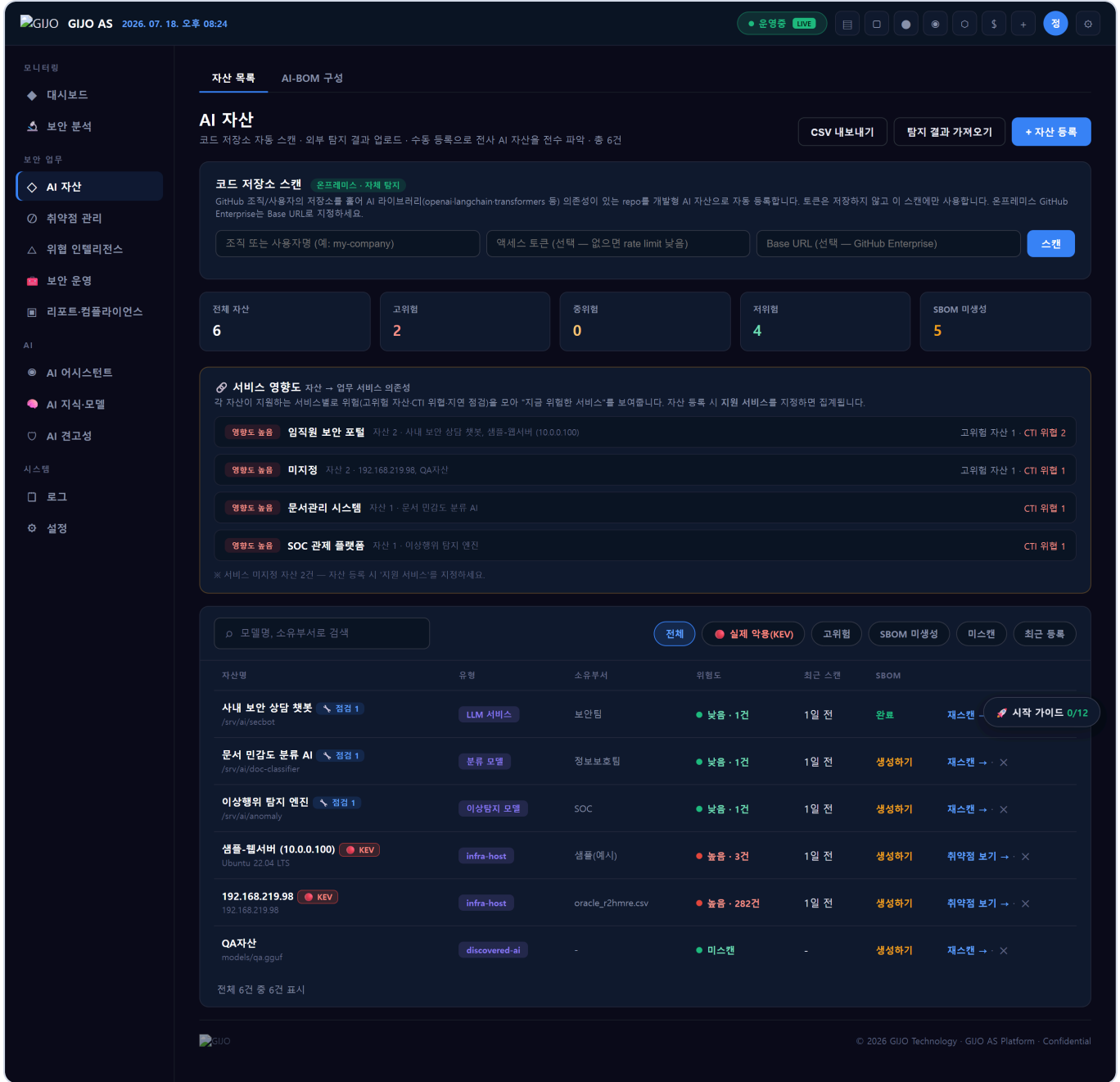
목적: "이 자산/보안제품 문제가 어느 업무 서비스에 영향?"을 자동으로.

자산을 업무 서비스로 묶어 위험(자산 취약점·CTI 위험·지연 점검)을 롤업합니다.

실측 — 서비스 3곳 모두 CTI 위험으로 "영향도 높음":

서비스	자산	영향도	위험 요인
임직원 보안 포털	사내 보안 상담 챗봇	높음	CTI 위험 1
문서관리 시스템	문서 민감도 분류 AI	높음	CTI 위험 1
SOC 관제 플랫폼	이상행위 탐지 엔진	높음	CTI 위험 1

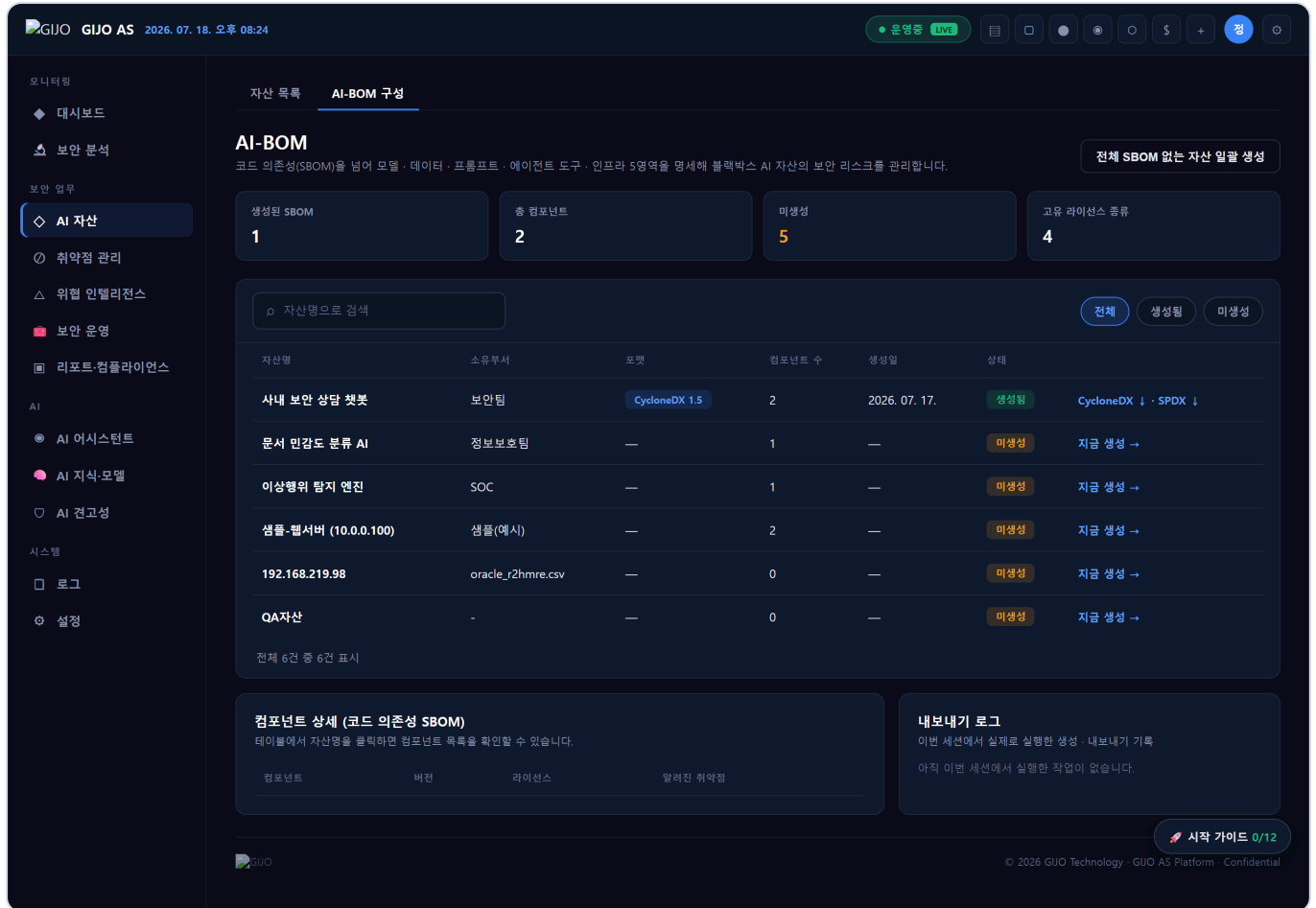
위험 → 자산 → 서비스까지 한 번에 연결. "지금 위험한 서비스"를 임원에게 바로 설명.



4.4 📦 자산 인벤토리 · AI-BOM · SBOM

목적: AI 자산뿐 아니라 받는 다양한 정보를 구성명세로 관리하고 취약점을 빠르게 확인.

- **자산 인벤토리:** AI 자산 + 일반 IT 자산(Nessus 업로드), 컴포넌트·소유부서·지원 서비스
- **AI-BOM:** 모델·데이터·프롬프트·도구·인프라 5영역 명세
- **SBOM 내보내기:** CycloneDX 및 SPDX-2.3 표준 지원



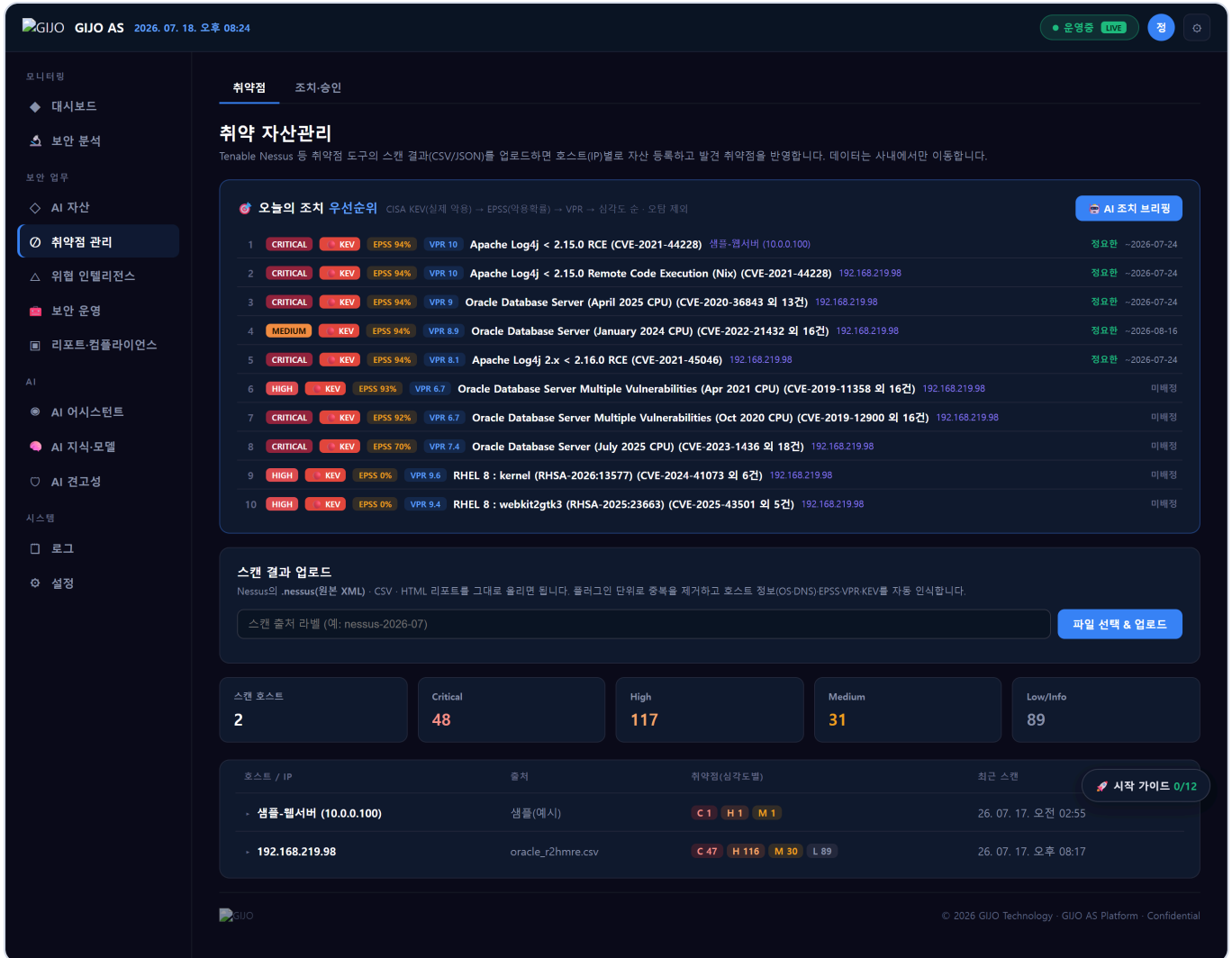
4.5 🛡️ 취약점 생애주기 관리 (Nessus)

목적: 취약점을 "목록"이 아니라 **발견** → **우선순위** → **조치** → **측정** 생애주기로 관리(Tenable 방법론 채택).

- **임포트:** Nessus .nessus (원본 XML) · CSV · HTML 리포트를 그대로 업로드. **플러그인 단위로 중복 제거**(1,171행 → 282건), 호스트 정보(OS·DNS)·EPSS·VPR·**CISA KEV** 자동 인식
- **우선순위:** CVSS 심각도에 더해 실제 악용확률(EPSS)·KEV로 정렬 — "Medium인데 악용 94%"를 놓치지 않음
- **상태 추적:** 재스캔 대비 New/Active/**Fixed**/Resurfaced 자동 판정. 인증(credentialed) 스캔 여부로 "**Fixed 검증 신뢰도**"까지 표시
- **조치:** 취약점을 담당자·**SLA**(KEV 7일 / Critical 14일 / High 30일...) 붙은 조치 항목으로 전환
- **측정:** 실제 스캔 이력에서 재구성한 **변다운**으로 위험 감소 추적

실측 — 샘플 취약 호스트 1대: **Log4Shell**(Critical · CISA KEV 실제 악용) · OpenSSH(High) · Oracle 패치 누락(Medium · 악용확률 ↑) · SSL(**Fixed**로 검증) — 심각도·KEV·상태를 한눈에.

실 Nessus 리포트는 1,171행을 282개 플러그인으로 중복 제거하는 것도 실패데이터로 검증했습니다.



4.6 보안제품 관리 (종류별 + 매뉴얼)

목적: 운영 중인 보안제품을 **종류별로 등록**하고, 제품 매뉴얼을 **AI가 학습**해 오케스트레이터가 참고.

- **종류별 등록:** 방화벽·EDR·DLP·WAF·VPN·IPS·SIEM·백신·NAC 카탈로그로 구분 관리, 대시보드에서 한 눈에
- **매뉴얼 일괄 업로드:** 파일만 올리면 파일명으로 어느 제품 문서인지 자동 매칭(없으면 제품 자동 등록), 로그 관련 파일은 **로그 매뉴얼**로 자동 분류
- **AI 학습(RAG):** 첨부한 매뉴얼은 지식베이스에 자동 수집 → "올린 문서 검색"과 **오케스트레이터** 답변에 즉시 반영
- **점검 연결:** 유지보수 점검과 제품을 이름 매칭으로 연결 → 제품 카드에서 점검 현황(지연·승인대기·다음 점검일) 확인

실측 — 4종 제품(방화벽·EDR·DLP·WAF) + 제품/로그 매뉴얼을 종류별 그룹으로 관리.

모니터링

◆ 대시보드

🔍 보안 분석

보안 업무

◇ AI 자산

🕒 취약점 관리

△ 위협 인텔리전스

📁 보안 운영

📁 리포트-컴플라이언스

AI

● AI 어시스턴트

🌸 AI 지식-모델

🛡️ AI 견고성

시스템

📄 로그

⚙️ 설정

보안제품

유지보수

📁 보안제품 관리

운영 중인 보안제품을 종류(방화벽, EDR, DLP, WAF, VPN 등)별로 등록하고, 제품별로 제품 매뉴얼과 로그(분석) 매뉴얼을 넣어 관리합니다. 대시보드에서 종류별로 한눈에 보고, 유지보수 점검(운영 가이드)과 연결됩니다.

- 파일을 첨부한 매뉴얼은 텍스트가 지식베이스(장기 기억)에 자동 수집되어 대시보드 "🔍 올린 문서 검색"에서도 바로 찾아지고, 오케스트레이터가 답변에 참고합니다.
- 종류(category)로 묶어 관리하면 담당자가 "무슨 제품을 운영 중이고 그 제품 문서는 어디 있나"를 한눈에 파악합니다.

📁 매뉴얼 일괄 업로드 — 파일만 올리면 자동 반영

취약점 스캔(Nessus) 업로드처럼, 매뉴얼 파일을 올리면 파일명으로 어느 제품 문서인지 자동 매칭하고(매칭할 제품이 없으면 제품까지 자동 등록), 로그 관련 파일은 로그 매뉴얼로 분류합니다. 처음 세팅할 때 매뉴얼들을 한꺼번에 올리세요

파일 선택 선택된 파일 없음

방화벽 1 EDR (단말탐지대응) 1 DLP (정보유출방지) 1 WAF (웹방화벽) 1 VPN 0 IPS/IDS (침입방지) 0 SIEM (통합로그관리) 0 백신 (안티바이러스) 0 NAC (접근제어) 1 기타 1

제품명 (예: 경계 방화벽 FW-0)

방화벽

제조사 (선택)

모델/버전 (선택)

연결 자산 없음

+ 제품 등록

📁 방화벽 1개 제품

경계 방화벽 (FW-01) SECU · MF2

× 제품 삭제

🔍 점검 1건 · 자연 1 →

■ 제품 매뉴얼

FW-01_경계방화벽_운영매뉴얼_v2 🔍 검색가능

필요한 ×

문서 제목 (파일 없이 제목만 등록도 가능)

파일 선택

선택된 파일 없음

+ 추가

□ 로그 매뉴얼

아직 없음 — 아래에서 추가하세요.

문서 제목 (파일 없이 제목만 등록도 가능)

파일 선택

선택된 파일 없음

+ 추가

📖 시작 가이드 0/12

📁 EDR (단말탐지대응) 1개 제품

임직원 단말 EDR

× 제품 삭제

🔍 점검 이력 없음 — 점검 등록 →

■ 제품 매뉴얼

아직 없음 — 아래에서 추가하세요.

문서 제목 (파일 없이 제목만 등록도 가능)

파일 선택

선택된 파일 없음

+ 추가

□ 로그 매뉴얼

아직 없음 — 아래에서 추가하세요.

EDR_임직원단말_로그분석_매뉴얼 🔍 검색가능

필요한 ×

문서 제목 (파일 없이 제목만 등록도 가능)

파일 선택

선택된 파일 없음

+ 추가

📁 DLP (정보유출방지) 1개 제품

정보유출 방지 (DLP)

× 제품 삭제

🔍 점검 이력 없음 — 점검 등록 →

■ 제품 매뉴얼

아직 없음 — 아래에서 추가하세요.

문서 제목 (파일 없이 제목만 등록도 가능)

파일 선택

선택된 파일 없음

+ 추가

□ 로그 매뉴얼

아직 없음 — 아래에서 추가하세요.

문서 제목 (파일 없이 제목만 등록도 가능)

파일 선택

선택된 파일 없음

+ 추가

📁 WAF (웹방화벽) 1개 제품

웹방화벽 (WAF-01)

× 제품 삭제

🔍 점검 1건 · 점검 완료 →

■ 제품 매뉴얼

아직 없음 — 아래에서 추가하세요.

문서 제목 (파일 없이 제목만 등록도 가능)

파일 선택

선택된 파일 없음

+ 추가

□ 로그 매뉴얼

아직 없음 — 아래에서 추가하세요.

문서 제목 (파일 없이 제목만 등록도 가능)

파일 선택

선택된 파일 없음

+ 추가

📁 NAC (접근제어) 1개 제품

Genian_NAC_관리자_매뉴얼_v1

× 제품 삭제

매뉴얼 일괄 업로드로 자동 등록

🔍 점검 이력 없음 — 점검 등록 →

■ 제품 매뉴얼

Genian_NAC_관리자_매뉴얼_v1 🔍 검색가능

필요한 ×

문서 제목 (파일 없이 제목만 등록도 가능)

파일 선택

선택된 파일 없음

+ 추가

□ 로그 매뉴얼

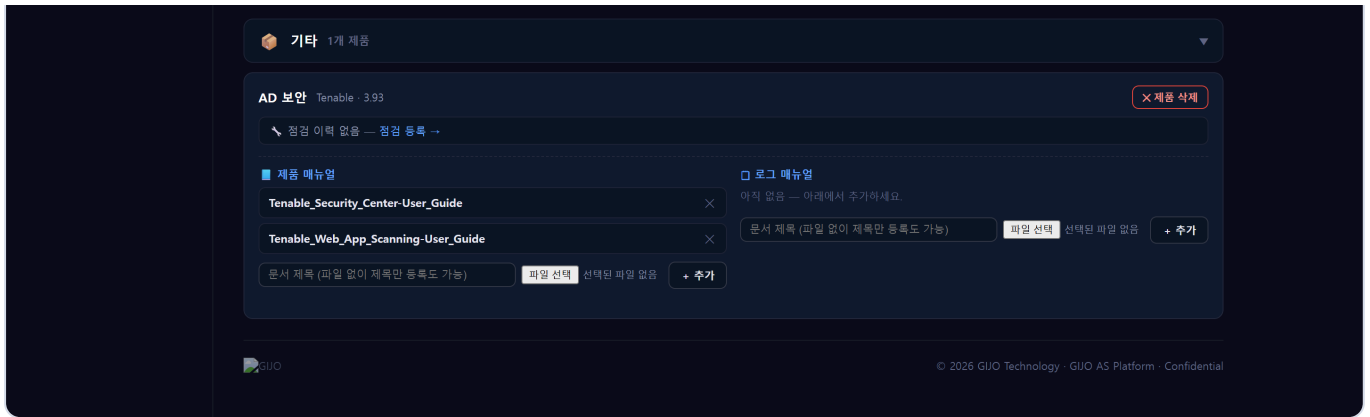
아직 없음 — 아래에서 추가하세요.

문서 제목 (파일 없이 제목만 등록도 가능)

파일 선택

선택된 파일 없음

+ 추가



4.7 취약점 승인 워크플로우 (거버넌스)

목적: 스캔 finding을 검토해 확정/오탐 처리 → SBOM 반영 게이트.

담당자가 finding을 **승인(확정)** 또는 **반려(오탐)** 처리. 반려된 오탐은 SBOM 취약점에서 자동 제외.
finding 내용 해시로 상태를 저장해 **재스캔 후에도 검토 결과 유지**.

모니터링

◆ 대시보드

🔍 보안 분석

🔧 작업 세션

보안 업무

◇ AI 자산

🔍 취약점 관리

△ 위협 인텔리전스

🔒 보안 운영

📄 리포트-웹플라이언스

AI

● AI 어시스턴트

🔴 AI 지식-모델

🛡️ AI 견고성

시스템

📄 로그

⚙️ 설정

취약점 조치·승인

조치·승인

스캔 finding을 **확정(승인)/오탐(반려)**으로 판정하고, 확정 건에 담당자·기한(SLA)을 붙여 조치를 관리합니다. 기한이 지난 미조치 건은 **지연**으로 표시됩니다.

전체 finding

289

미검토

238

승인(확정)

51

반려(오탐)

0

지연(기한초과)

0

Finding 검토

자산별 스캔 finding 목록, 승인 = 실제 위험으로 확정, 반려 = 오탐 처리(SBOM에서 제외).

미검토 high OpenSSH < 9.6 사용자 열거 (CVE-2024-6387) 선폰-웹서버 (10.0.0.100)

승인

반려(오탐)

포트: tcp/22 (성능)

담당자 미배정

기한

년 - 월 - 일

📅

미검토 high Oracle Database Server Multiple Vulnerabilities (Jan 2021 CPU) (CVE-2020-10878 외 8건) 192.168.219.98

승인

반려(오탐)

The versions of Oracle Database Server installed on the remote host are affected by multiple vulnerabilities as referenced in the January 2021 CPU advisory. - Vulnerability in the RDBMS Scheduler component of Oracle Database Server. Supported versions that are affected are 12.1.0.2, 12.2.0.1, 18c and 19c. Easily exploitable vulnerability allows low privileged attacker having Export Full Database privilege with network access via Oracle Net to compromise RDBMS Scheduler. Successful attacks of this vulnerability can result in takeover of RDBMS Scheduler. (CVE-2021-2035) - Vulnerability in the Advanced Networking Option component of Oracle Database Server. Supported versions that are affected are 18c and 19c. Difficult to exploit vulnerability allows unauthenticated attacker with network access via Oracle Net to compromise Advanced Networking Option. Successful attacks require human interaction from a person other than the attacker and while the vulnerability is in Advanced Networking Option, attacks may significantly impact additional products. Successful attacks of this vulnerability can result in takeover of Advanced Networking Option. Note: CVE-2021-2018 affects Windows platform only. (CVE-2021-2018) - Vulnerability in the RDBMS Sharding component of Oracle Database Server. Supported versions that are affected are 12.2.0.1, 18c and 19c. Easily exploitable vulnerability allows high privileged attacker having Create Any Procedure, Create Any View, Create Any Trigger privilege with network access via Oracle Net to compromise RDBMS Sharding. Successful attacks of this vulnerability can result in takeover of RDBMS Sharding. (CVE-2021-2054) Note that Nessus has not tested for this issue but has instead relied only on the application's self-reported version number. CVE(9): CVE-2020-10878, CVE-2021-1993, CVE-2021-2000, CVE-2021-2018, CVE-2021-2035, CVE-2021-2045, CVE-2021-2054, CVE-2021-2116, CVE-2021-2117 (oracle_2hmr.csv)

담당자 미배정

기한

년 - 월 - 일

📅

미검토 high Oracle Database Server Multiple Vulnerabilities (Apr 2021 CPU) (CVE-2019-11358 외 16건) 192.168.219.98

승인

반려(오탐)

The versions of Oracle Database Server installed on the remote host are affected by multiple vulnerabilities as referenced in the April 2021 CPU advisory. - Vulnerability in the Oracle Database - Enterprise Edition Security (Dell BSAFE Micro Edition Suite) component of Oracle Database Server. Supported versions that are affected are 12.1.0.2, 12.2.0.1, 18c and 19c. Easily exploitable vulnerability allows unauthenticated attacker with network access via multiple protocols to compromise Oracle Database - Enterprise Edition Security (Dell BSAFE Micro Edition Suite). Successful attacks of this vulnerability can result in unauthorized access to cause a hang or frequently repeatable crash (complete DOS) of Oracle Database - Enterprise Edition Security (Dell BSAFE Micro Edition Suite). (CVE-2020-5360) - Vulnerability in the Workload Manager (Apache Tomcat) component of Oracle Database Server. Supported versions that are affected are 18c and 19c. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Workload Manager (Apache Tomcat). Successful attacks of this vulnerability can result in unauthorized access to critical data or complete access to all Workload Manager (Apache Tomcat) accessible data. (CVE-2020-17527) - Vulnerability in the Oracle Database - Enterprise Edition (Dell BSAFE Crypto-J) component of Oracle Database Server. Supported versions that are affected are 12.1.0.2, 12.2.0.1, 18c and 19c. Easily exploitable vulnerability allows unauthenticated attacker with network access via Oracle Net to compromise Oracle Database - Enterprise Edition (Dell BSAFE Crypto-J). Successful attacks require human interaction from a person other than the attacker. Successful attacks of this vulnerability can result in unauthorized access to critical data or complete access to all Oracle Database - Enterprise Edition (Dell BSAFE Crypto-J) accessible data. (CVE-2019-3740). Note that Nessus has not tested for this issue but has instead relied only on the application's self-reported version number. CVE(17): CVE-2019-11358, CVE-2019-3738, CVE-2019-3739, CVE-2019-3740, CVE-2020-11022, CVE-2020-11023, CVE-2020-13943, CVE-2020-17527, CVE-2020-5359, CVE-2020-5360, CVE-2020-7760, CVE-2020-9484, CVE-2021-2173, CVE-2021-2175, CVE-2021-2207, CVE-2021-2234, CVE-2021-2245 △ CISA KEV(실제 약용 확인): CVE-2020-11023 (oracle_2hmr.csv)

담당자 미배정

기한

년 - 월 - 일

📅

미검토 high Apache Log4j 1.2 JMSAppender Remote Code Execution (CVE-2021-4104) 192.168.219.98

승인

반려(오탐)

The version of Apache Log4j on the remote host is 1.2. It is, therefore, affected by a remote code execution vulnerability when specifically configured to use JMSAppender. Note that Nessus has not tested for these issues but has instead relied only on the application's self-reported version number. (oracle_2hmr.csv)

담당자 미배정

기한

년 - 월 - 일

📅

미검토 high Oracle Database Server for Unix (Jan 2023 CPU) (CVE-2018-25032 외 15건) 192.168.219.98

승인

반려(오탐)

The versions of Oracle Database Server installed on the remote host are affected by multiple vulnerabilities as referenced in the January 2023 CPU advisory. - Vulnerability in the Oracle Database - Machine Learning for Python (Python) component of Oracle Database Server. The supported version that is affected is 21c. Easily exploitable vulnerability allows low privileged attacker having Database User privilege with network access via Oracle Net to compromise Oracle Database - Machine Learning for Python (Python). Successful attacks of this vulnerability can result in unauthorized access to cause a hang or frequently repeatable crash (complete DOS) of Oracle Database - Machine Learning for Python (Python). (CVE-2021-3737) - Vulnerability in the Oracle Database RDBMS Security component of Oracle Database Server. Supported versions that are affected are 19c and 21c. Easily exploitable vulnerability allows low privileged attacker having Create Session privilege with network access via Oracle Net to compromise Oracle Database RDBMS Security. Successful attacks require human interaction from a person other than the attacker. Successful attacks of this vulnerability can result in unauthorized creation, deletion or modification access to critical data or all Oracle Database RDBMS Security accessible data as well as unauthorized read access to a subset of Oracle Database RDBMS Security accessible data. (CVE-2023-21829) - Vulnerability in the Java VM component of Oracle Database Server. Supported versions that are affected are 19c and 21c. Easily exploitable vulnerability allows low privileged attacker having Create Procedure privilege with network access via Oracle Net to compromise Java VM. Successful attacks of this vulnerability can result in unauthorized ability to cause a partial denial of service (partial DOS) of Java VM. (CVE-2022-39429) - Vulnerability in the Oracle Database Data Redaction component of Oracle Database Server. Supported versions that are affected are 19c and 21c. Easily exploitable vulnerability allows low privileged attacker having Create Session privilege with network access via Oracle Net to compromise Oracle Database Data Redaction. Successful attacks of this vulnerability can result in unauthorized read access to a subset of Oracle Database Data Redaction accessible data. (CVE-2023-21827) Note that Nessus has not tested for these issues but has instead relied only on the application's self-reported version number. CVE(16): CVE-2018-25032, CVE-2020-10735, CVE-2020-10878, CVE-2021-29338, CVE-2021-3737, CVE-2021-3775, CVE-2022-1122, CVE-2022-21597, CVE-2022-3171, CVE-2022-39429, CVE-2022-42003, CVE-2022-42004, CVE-2022-42889, CVE-2022-45047, CVE-2023-21827, CVE-2023-21829 (oracle_2hmr.csv)

담당자 미배정

기한

년 - 월 - 일

📅

미검토 high Oracle Database Server (Jul 2024 CPU) (CVE-2022-41881 외 10건) 192.168.219.98

승인

반려(오탐)

The versions of Oracle Database Server installed on the remote host are affected by multiple vulnerabilities as referenced in the July 2024 CPU advisory. - Netty project is an event-driven asynchronous network application framework. In versions prior to 4.1.86.Final, a StackOverflowError can be raised when parsing a malformed crafted message due to an infinite recursion. This issue is patched in version 4.1.86.Final. There is no workaround, except using a custom HaProxyMessageDecoder. (CVE-2022-41881) - Netty project is an event-driven asynchronous network application framework. Starting in version 4.1.83.Final and prior to 4.1.86.Final, when calling 'DefaultHttpHeaders.set' with an 'iterator_' of values, header value validation was not performed, allowing malicious header values in the iterator to perform HTTP Response Splitting. This issue has been patched in version 4.1.86.Final. Integrators can work around the issue by changing the 'DefaultHttpHeaders.set(CharSequence, Iterator<?>)' call into a 'remove()' call, a 'nd call 'add()' in a loop over the iterator of values. (CVE-2022-41915) - A defect was discovered in the Python ssl module where there is a memory race condition with the ssl.SSLContext methods cert_store_stats() and get_ca_certs(). The race condition can be triggered if the methods are called at the same time as certificates are loaded into the SSLContext, such as during the TLS handshake with a certificate directory configured. This issue is fixed in CPython 3.10.14, 3.11.9, 3.12.3, and 3.13.0a5. (CVE-2024-0397) Note that Nessus has not tested for these issues but has instead relied only on the application's self-reported version number. CVE(11): CVE-2022-41881, CVE-2022-41915, CVE-2024-0397, CVE-2024-21098, CVE-2024-21123, CVE-2024-21126, CVE-2024-21174, CVE-2024-21184, CVE-2024-2511, CVE-2024-4603, CVE-2024-4741 (oracle_2hmr.csv)

담당자 미배정

기한

년 - 월 - 일

📅

미검토 high Oracle Database Server (January 2025 CPU) (CVE-2022-26345 외 11건) 192.168.219.98

승인

반려(오탐)

The versions of Oracle Database Server installed on the remote host are affected by multiple vulnerabilities as referenced in the January 2025 CPU advisory. - jrburke requirejs v2.3.6 was discovered to contain a prototype pollution via the function config. This vulnerability allows attackers to execute arbitrary code or cause a Denial of Service (DoS) via injecting arbitrary properties. (CVE-2024-38998) - Uncontrolled search path element in the Intel(R) oneAPI Toolkit OpenMP before version 2022.1 may allow an authenticated user to potentially enable escalation of privilege via local access. (CVE-2022-26345) - The SSH transport protocol with certain OpenSSH extensions, found in OpenSSH before 9.6 and other products, allows remote attackers to bypass integrity checks such that some packets are omitted (from the extension negotiation message), and a client and server may consequently end up with a connection for which some security features have been downgraded or disabled, aka a Terrapin attack. This occurs because the SSH Binary Packet Protocol (BPP), implemented by these extensions, mishandles the handshake phase and mishandles use of sequence numbers. For example, there is an effective attack against SSH's use of ChaCha20-Poly1305 (and CBC with Encrypt-then-MAC). The bypass occurs in chacha20-poly1305@openssh.com and (if CBC is used) the -etm@openssh.com MAC algorithms. This also affects Mavericks Synergy Java SSH API before 3.1.0-SNAPSHOT, Dropbear through 2022.83, Ssh before 5.1.1 in Erlang/OTP PuTTY before 0.80, AsyncSSH before 2.14.2, golang.org/x/crypto before 0.17.0, libssh before 0.10.6, libssh2 through 1.11.0, Thor Tech SFTP Gateway before 3.4.6, Tera Term before 5.1, Paramiko before 3.4.0, jsch before 0.2.15, SFTPG before 2.5.6, Netgate pSense Plus through 23.09.1, Netgate pfSense CE through 2.7.2, HPN-SSH through 18.2.0, ProFTPD before 1.3.8b (and before 1.3.9rc2), ORyx CycloneSSH before 2.3.4, NetSarang XShell 7 before Build 0144, CrushFTP before 10.6.0, ConnectBot SSH library before 2.2.22, Apache MINA sshd through 2.11.0, sshj through 0.37.0, TinySSH through 20230101, trilead-ssh2 6401, LANCOM LCOS and LANconfig, FileZilla before 3.66.4, Nova before 11.8, PKIX-SSH before 14.4, SecureCRT before 9.4.3, Transmit5 before 5.10.4, Win32-OpenSSH before 9.5.0.0p1-Beta, WinSCP before 6.2.2, Bitvise SSH Server before 9.32, Bitvise SSH Client before 9.33, KiTTY through 0.76.1,

13, the net-ssh gem 7.2.0 for Ruby, the mscdex ssh2 module before 1.15.0 for Node.js, the thrush library before 0.35.1 for Rust, and the Russh crate before 0.40.2 for Rust. (CVE-2023-48795) - In Connect2id Nimbus JOSE+JWT before 9.37.2, an attacker can cause a denial of service (resource consumption) via a large JWE p2c header value (aka iteration count) for the PasswordBasedDecrypter (PBKDF2) component. (CVE-2023-52428) - Vulnerability in the Oracle Java SE, Oracle GraalVM for JDK, Oracle GraalVM Enterprise Edition product of Oracle Java SE (component: Compiler). Supported versions that are affected are Oracle Java SE: 23; Oracle GraalVM for JDK: 17.0.12, 21.0.4, 23; Oracle GraalVM Enterprise Edition: 20.3.15 and 21.3.11. Difficult to exploit vulnerability allows unauthenticated attacker with network access via multiple protocols to compromise Oracle Java SE, Oracle GraalVM for JDK, Oracle GraalVM Enterprise Edition. Successful attacks of this vulnerability can result in unauthorized update, insert or delete access to some of Oracle Java SE, Oracle GraalVM for JDK, Oracle GraalVM Enterprise Edition accessible data. Note: This vulnerability can be exploited by using APIs in the specified Component, e.g., through a web service which supplies data to the APIs. This vulnerability also applies to Java deployments, typically in clients running sandboxed Java Web Start applications or sandboxed Java applets, that load and run untrusted code (e.g., code that comes from the internet) and rely on the Java sandbox for security. (CVE-2024-21211) Note that Nessus has not tested for these issues but has instead relied only on the application's self-reported version number. CVE(12): CVE-2022-26345, CVE-2023-48795, CVE-2023-52428, CVE-2024-21211, CVE-2024-38998, CVE-2024-38999, CVE-2024-45772, CVE-2024-47554, CVE-2024-52316, CVE-2024-52317, CVE-2024-7254, CVE-2025-21553 (oracle_r2hmr.csv)

담당자 미배정 기한 년-월-일

미검토 high RHEL 8 : firefox (RHSA-2025-14442) (CVE-2025-9179 외 4건) 192.168.219.98

승인 반려(오답)

The remote Redhat Enterprise Linux 8 host has a package installed that is affected by multiple vulnerabilities as referenced in the RHSA-2025-14442 advisory. Mozilla Firefox is an open-source web browser, designed for standards compliance, performance, and portability. Security Fix(es): * firefox: thunderbird: Denial-of-service due to out-of-memory in the Graphics: WebRender component (CVE-2025-9183) * thunderbird: firefox: Sandbox escape due to invalid pointer in the Audio/Video: GMP component (CVE-2025-9179) * thunderbird: firefox: Same-origin policy bypass in the Graphics: Canvas2D component (CVE-2025-9180) * thunderbird: firefox: Uninitialized memory in the JavaScript Engine component (CVE-2025-9181) * thunderbird: firefox: Memory safety bugs fixed in Firefox ESR 115.27, Firefox ESR 128.14, Thunderbird ESR 128.14, Firefox ESR 140.2, Thunderbird ESR 140.2, Firefox 142 and Thunderbird 142 (CVE-2025-9185) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section. Tenable has extracted the preceding description block directly from the Red Hat Enterprise Linux security advisory. Note that Nessus has not tested for these issues but has instead relied only on the application's self-reported version number. CVE(5): CVE-2025-9179, CVE-2025-9180, CVE-2025-9181, CVE-2025-9182, CVE-2025-9185 (oracle_r2hmr.csv)

담당자 미배정 기한 년-월-일

미검토 high RHEL 8 : kernel (RHSA-2025-14438) (CVE-2025-22058 외 1건) 192.168.219.98

승인 반려(오답)

The remote Redhat Enterprise Linux 8 host has packages installed that are affected by multiple vulnerabilities as referenced in the RHSA-2025-14438 advisory. The kernel packages contain the Linux kernel, the core of any Linux operating system. Security Fix(es): * kernel: udp: Fix memory accounting leak. (CVE-2025-22058) * kernel: i40e: fix MMIO write access to an invalid page in i40e_clear_hw (CVE-2025-38200) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section. Tenable has extracted the preceding description block directly from the Red Hat Enterprise Linux security advisory. Note that Nessus has not tested for these issues but has instead relied only on the application's self-reported version number. CVE(2): CVE-2025-22058, CVE-2025-38200 (oracle_r2hmr.csv)

담당자 미배정 기한 년-월-일

미검토 high RHEL 8 : pam (RHSA-2025-14557) (CVE-2025-6020 외 1건) 192.168.219.98

승인 반려(오답)

The remote Redhat Enterprise Linux 8 host has packages installed that are affected by multiple vulnerabilities as referenced in the RHSA-2025-14557 advisory. Pluggable Authentication Modules (PAM) provide a system to set up authentication policies without the need to recompile programs to handle authentication. Security Fix(es): * linux-pam: Linux-pam directory Traversal (CVE-2025-6020) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section. Tenable has extracted the preceding description block directly from the Red Hat Enterprise Linux security advisory. Note that Nessus has not tested for these issues but has instead relied only on the application's self-reported version number. CVE(2): CVE-2025-6020, CVE-2025-8941 (oracle_r2hmr.csv)

담당자 미배정 기한 년-월-일

미검토 high RHEL 8 : python3 (RHSA-2025-14560) (CVE-2025-8194) 192.168.219.98

승인 반려(오답)

The remote Redhat Enterprise Linux 8 host has packages installed that are affected by a vulnerability as referenced in the RHSA-2025-14560 advisory. Python is an interpreted, interactive, object-oriented programming language, which includes modules, classes, exceptions, very high level dynamic data types and dynamic typing. Python supports interfaces to many system calls and libraries, as well as to various windowing systems. Security Fix(es): * cpython: Cpython infinite loop when parsing a tarfile (CVE-2025-8194) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section. Tenable has extracted the preceding description block directly from the Red Hat Enterprise Linux security advisory. Note that Nessus has not tested for this issue but has instead relied only on the application's self-reported version number. (oracle_r2hmr.csv)

담당자 미배정 기한 년-월-일

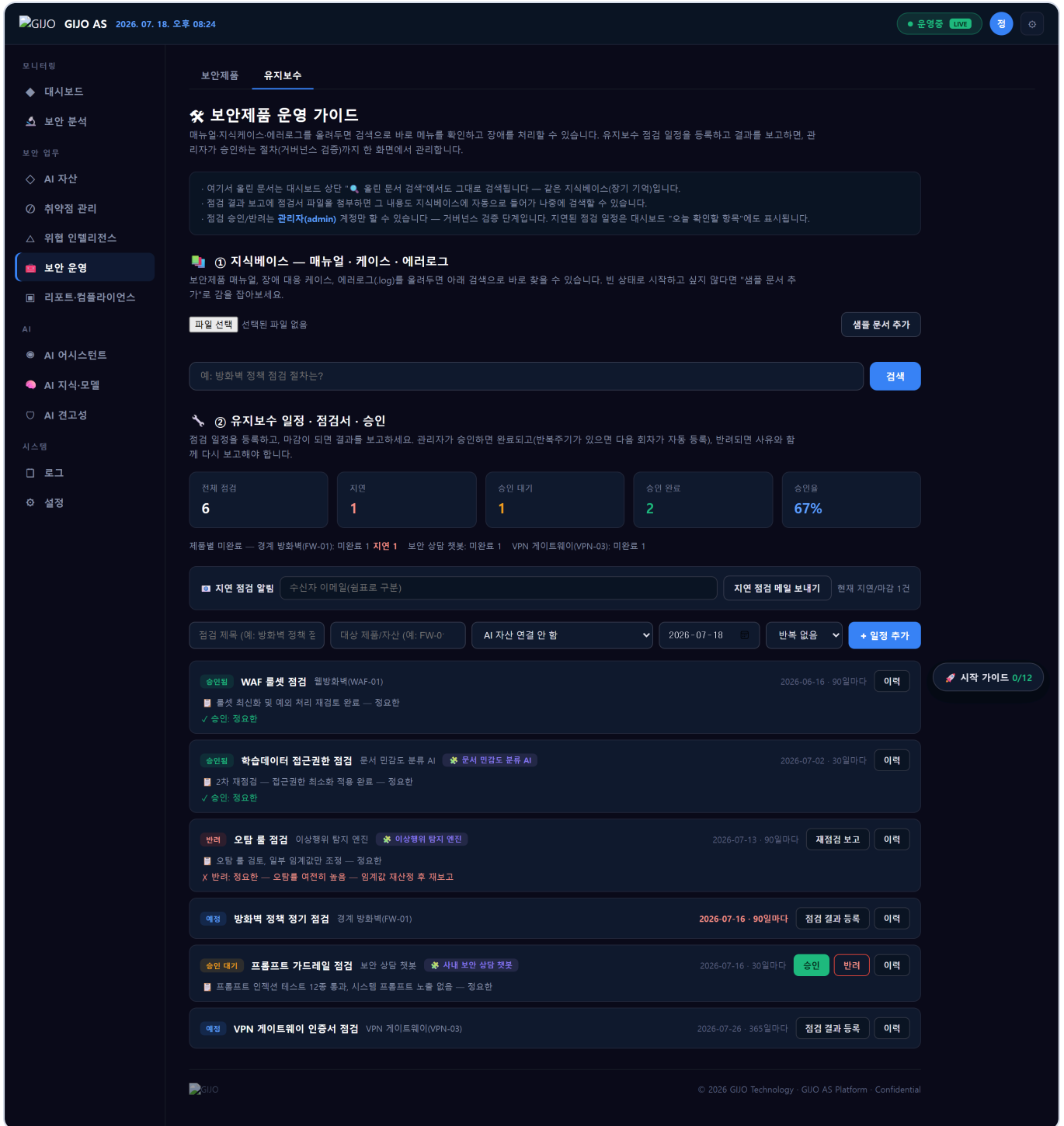
4.8 ✂ 보안제품 운영 가이드 (유지보수 거버넌스)

목적: 패치-메뉴 확인-장애 대응을 일정→보고→승인 거버넌스로.

- 지식베이스: 매뉴얼-에러로그(.log) 업로드 → RAG 검색으로 메뉴 확인-장애처리
- 점검 거버넌스: 일정 등록 → 결과 보고 → 관리자 승인/반려 (반복주기 자동 생성)
- 이력 타임라인 + 이메일 알림: 지연 점검을 담당자에게 자동 통지

실측 — 점검 6건(전 상태 시연):

점검	대상	상태
방화벽 정책 정기 점검	경계 방화벽(FW-01)	예정(오늘 마감)
프롬프트 가드레일 점검	보안 상담 챗봇	승인 대기
학습데이터 접근권한 점검	문서 민감도 분류 AI	승인됨
오탐 룰 점검	이상행위 탐지 엔진	반려
WAF 룰셋 점검	웹방화벽(WAF-01)	승인됨
VPN 게이트웨이 인증서 점검	VPN 게이트웨이(VPN-03)	예정



4.9 로컬 LLM · RAG · 헤르메스 학습 루프

목적: 온프레미스 AI로 연속성 유지, 쓸수록 똑똑해지는 자가학습.

- 로컬 LLM: llama.cpp 멀티모델 풀(RTX 3090), 에이전트별 모델 배정
- RAG(장기 기억): 사내 문서를 LanceDB에 넣어 검색·근거 주입
- 헤르메스 폐쇄형 학습 루프: 실제 대화 자동 수집 → 👍 정제 → QLoRA 학습 → GGUF 배포 (전 과정 폐쇄망, 사전점검 포함)

모니터링

대시보드

보안 분석

작업 세션

보안 업무

AI 자산

취약점 관리

위협 인텔리전스

보안 운영

리포트-컴플라이언스

AI

AI 어시스턴트

AI 지식-모델

AI 견고성

시스템

로그

설정

기억-학습

온도-로지

학습 루프

헤르메스 학습 루프

에이전트와 나눈 실제 대화가 자동으로 수집되고, 담당자가 🗨️로 승인한 것만 데이터셋이 되어 로컬 GPU에서 학습(QLoRA)됩니다. 학습된 모델은 GGUF로 변환돼 에이전트에 자동 배포 — 이 모든 과정이 **패쇄망 안에서만** 들킵니다.

- **패쇄형**: 대화-데이터셋-학습-배포 전 과정이 이 서버(GPU 머신) 안에서만 이루어지고 외부로 나가지 않습니다.
- 루프 실행 중에는 GPU를 학습이 독점하므로 **채팅-문서검색(RAG)**이 일시 중지됩니다가 끝나면 자동 재개됩니다.
- 베이스 모델(기본 **Hermes 3 - Llama 3.1 8B**)의 학습용 원본 가중치는 첫 실행 전에 미리 받아둬야 합니다 — 패쇄망 이전 시 **hf download NousResearch/Hermes-3-Llama-3.1-8B** 실행, 배포 모델은 **버전(-v1, -v2...)**으로 끌어 언제든 이전 버전으로 되돌릴 수 있습니다.

STEP 1

수집

에이전트 실제 대화(질문-답변)를 자동 저장 — 아래 목록에서 확인

STEP 2

정제

담당자가 🗨️한 대화만 골라 학습 데이터셋으로 변환

STEP 3

학습

Hermes 3 베이스에 QLoRA 파인튜닝 (RTX 3090 권장)

STEP 4

배포

GGUF 변환 후 대상 에이전트에 새 버전 자동 할당 (모니터)

수집된 대화

200

조정 평가

0

학습 후보(미사용)

200

최근 배포 모델

아직 없음

사전 점검

실행 전에 준비물(Python-unsloth-gguf-llama.cpp 베이스 모델 캐시)을 확인합니다. 하나라도 빠지면 실행 도중에 실패하니, **모두 충족**인지 먼저 확인하세요.

▲ 준비물이 빠져 있습니다 — 아래 항목을 갖춘 뒤 실행하세요.

- ✓ Python 실행 가능 Python 3.12.10
- ✓ unsloth (QLoRA 학습)
- ✓ gguf 파키지 (GGUF 변환)
- ✓ llama.cpp 변환 스크립트
- ✓ llama.cpp 양자화 빌드
- ✗ 베이스 모델 캐시 (NousResearch/Hermes-3-Llama-3.1-8B)
 - hf download NousResearch/Hermes-3-Llama-3.1-8B
- ! 학습 데이터(🗨️ 대화) 현재 0건
 - 대화를 더 수집하고 🗨️를 남기거나, 기존 데이터셋으로 실행하세요.

다시 점검

루프 실행

원클릭 실행 시 | 🗨️ 로그 → 데이터셋 → 학습 → GGUF 변환 → 에이전트 배포가 순서대로 진행됩니다. 각 단계는 아래에 실시간 표시됩니다.

루프 실행 (원클릭)

데이터셋만 만들기

아직 실행 이력이 없습니다.

루프 설정

모델-대상은 인증하 바꾸세요. 베이스 모델은 HuggingFace 원본 repo id(HF transformers)이며, GGUF id가 아닙니다.

학습 베이스 모델 (HF repo)

배포 모델 침두어

배포 대상 에이전트

대화 자동 수집

NousResearch/Hermes-3-Llama-3.1-8B

hermes-sec-tuned

Security Orchestrator

저장

수집된 대화

좋은 답변에 🗨️를 남기면 다음 학습에 채택됩니다. 🗨️/삭제된 대화는 학습에서 제외됩니다. 이미 학습에 쓰인 대화는 ✓ 표시.

Q. 이전 대화 맥락(같은 세션): AI: 🗨️ 사내 보안 담당 챗봇 (ai-secbot-01) 취약점 low 1 · 최근 스캔 2026. 7. 18. AI-BOM Qwen2.5-7B-Instruct · 견고성 미검정 · 서비스 임
직렬 보안 포털 사용자: 사내 보안 담당 챗봇 취약점 조치 절차 알려줘 AI: 사내 보안 담당 챗봇 (ai-secbot-01)의 취약점 조치 절차는 다음과 같습니다: 1. **최신 패치 적용**:
- AI-BOM Qwen2.5-7B-Instruct의 최신 버전으로 업데이트해야 합니다. 이는 보안 취약점을 해결하고 최신 보안 패치를 포함하고 있기 때문입니다. 2. **설정 강화**:
- 챗봇의 설정을 강화하여 불필요한 기능과 권한을 제거합니다. 특히, 챗봇이 내부 시스템에 접근할 수 있는 권한이 과도하지 않도록 확인합니다. 3. **접근 통제**:
- 챗봇의 접근을 엄격히 제한합니다. 필요한 사용자만 챗봇을 사 사용자: 레포트 가능해? AI: 가능합니다. AI 보안 담당 챗봇 (ai-secbot-01)의 취약점 조치 절차와 관련 리포팅을 제공하겠습니다. ## AI 보안 담당 챗봇 (ai-secbot-01) 취약점 조치 리포트 **1. 최신 패치 적용** - **취약점**:
AI-BOM Qwen2.5-7B-Instruct의 견고성 미검정 · **조치**:
최신 버전으로 업데이트하여 보안 취약점을 해결하고 최신 보안 패치를 포함하도록 합니다. - **근거**:
KISA AI 보안 위협 대응 매뉴얼 (2026.7) **2. 설정 강화** - **취약점**:
설정이 약하거나 사용자 지사: "사내 보안 담당 챗봇 레드팀 점검해줘" 방금 시스템에서 조회한 실제 데이터: [1] threats: 최신 위협 55건 중 우리 자산에 걸리는 것 46건 (영향 자산 5개, 심각 정도 3건): - [critical] 악성 패치지 — bge-m3 임베딩 모델 배포 패키지에 악성코드 삽입 사례 보고 (출처 생략(데모)) → 우리 자산: 사내 보안 담당 챗봇(id=ai-secbot-01) - [warning] 위협 캠페인, 공급망 — Qwen2.5 오픈웨이트 모델 가중치 변조 공급망 위협 정황 (출처 생략(데모)) → 우리 자산: 사내 보안 담당 챗봇(id=ai-secbot-01) - [warning] 프롬프트 인젝션 — KoBERT 기반 한국어 분류 모델 대량 프롬프트 인젝션 캠페인 (출처 생략(데모)) → 우리 자산: 문서 민감도 분류 AI(id=ai-doccls-02) - [info] 위협 인텔 Pulse — Botnet Analysis: A Product-Grade Threat for the AI Service Era (출처 LevelBlue OTX) → 우리 자산: 192.168.219.98(id=vuln:192.168.219.98) - [info] 위협 캠페인 - Contagious Interview — Contagious Interview malware in SVG images: DPRK campaign (출처 LevelBlue OTX) → 우리 자산: 192.168.219.98(id=vuln:192.168.219.98) 위 데이터만 근거로 지사에 대한 최종 답변을 작성하라. 데이터에 없는 내용은 지어내지 마라.

A. ## 레드팀 점검 요약 ##### 1. **악성 패치지 위협** - **취약점**:
악성 패치지 — bge-m3 임베딩 모델 배포 패키지에 악성코드 삽입 사례 보고 - **해당 자산**:
사내 보안 담당 챗봇 (ai-secbot-01) - **점검 결과**:
챗봇이 배포 패키지에서 악성코드가 삽입되었는지 검토해야 합니다. 특히, 배포 과정에서 악성코드가 포함되지 않았는지 확인합니다. ##### 2. **공급망 위협** - **취약점**:
Qwen2.5 오픈웨이트 모델 가중치 변조 공급망 위협 정황 - **해당 자산**:
사내 보안 담당 챗봇 (ai-secbot-01) - **점검 결과**:
Qwen2.5 모델의 가중치가 변

orchestrator 07. 18. 오후 11:27

👍 🗨️ ✖

Q. 이전 대화 맥락(같은 세션): AI: 🗨️ 사내 보안 담당 챗봇 (ai-secbot-01) 취약점 low 1 · 최근 스캔 2026. 7. 18. AI-BOM Qwen2.5-7B-Instruct · 견고성 미검정 · 서비스 임
직렬 보안 포털 사용자: 지사: "사내 보안 담당 챗봇 취약점 조치 절차 알려줘" 방금 시스템에서 조회한 실제 데이터: [1] remediation: "사내 보안 담당 챗봇"에 대한 사내 완
화통제-보안제품-매뉴얼 근거를 찾지 못했습니다. 일반적 조치는 최신 패치 적용-설정 강화-접근통제이며, 관련 매뉴얼을 올리면 구체 절차가 제공됩니다. 위 데이터만 근거로 지
사에 대한 최종 답변을 작성하라. 데이터에 없는 내용은 지어내지 마라.

A. 사내 보안 담당 챗봇 (ai-secbot-01)의 취약점 조치 절차는 다음과 같습니다: 1. **최신 패치 적용** - AI-BOM Qwen2.5-7B-Instruct의 최신 버전으로 업데이트해야 합니다. 이는 보
안 취약점을 해결하고 최신 보안 패치를 포함하고 있기 때문입니다. 2. **설정 강화** - 챗봇의 설정을 강화하여 불필요한 기능과 권한을 제거합니다. 특히, 챗봇이 내부 시스템에 접
근할 수 있는 권한이 과도하지 않도록 확인합니다. 3. **접근 통제** - 챗봇의 접근을 엄격히 제한합니다. 필요한 사용자만 챗봇을 사용할 수 있도록 인증 절차를 강화합니다. 이는 해

report 07. 18. 오후 11:26

👍 🗨️ ✖

Q. 이전 대화 맥락(같은 세션): AI: 🗨️ 사내 보안 담당 챗봇 (ai-secbot-01) 취약점 low 1 · 최근 스캔 2026. 7. 18. AI-BOM Qwen2.5-7B-Instruct · 견고성 미검정 · 서비스 임
직렬 보안 포털 사용자: 지사: "사내 보안 담당 챗봇 취약점 조치 절차 알려줘" 방금 시스템에서 조회한 실제 데이터: [1] remediation: "사내 보안 담당 챗봇"에 대한 사내 완
화통제-보안제품-매뉴얼 근거를 찾지 못했습니다. 일반적 조치는 최신 패치 적용-설정 강화-접근통제이며, 관련 매뉴얼을 올리면 구체 절차가 제공됩니다. 위 데이터만 근거로 지
사에 대한 최종 답변을 작성하라. 데이터에 없는 내용은 지어내지 마라.

A. 사내 보안 담당 챗봇 (ai-secbot-01)의 취약점 조치 절차는 다음과 같습니다: 1. **최신 패치 적용** - AI-BOM Qwen2.5-7B-Instruct의 최신 버전으로 업데이트해야 합니다. 이는 보
안 취약점을 해결하고 최신 보안 패치를 포함하고 있기 때문입니다. 2. **설정 강화** - 챗봇의 설정을 강화하여 불필요한 기능과 권한을 제거합니다. 특히, 챗봇이 내부 시스템에 접
근할 수 있는 권한이 과도하지 않도록 확인합니다. 3. **접근 통제** - 챗봇의 접근을 엄격히 제한합니다. 필요한 사용자만 챗봇을 사용할 수 있도록 인증 절차를 강화합니다. 이는 해



4.10 통합 보안 KPI 대시보드

목적: 흩어진 지표를 한곳에 + 매일 스냅샷으로 추세 → 임원 보고·방향성 결정.

번다운·SLA 준수율·KEV 추세까지 한 화면에 모읍니다.

실측 — 통합 스냅샷(2026-07-17):

도메인	지표
취약점(Nessus)	열린 3 · Critical 1(Log4Shell) · KEV 1 · 번다운 추세
자산	전체 4 (AI 자산 3 + 취약점 스캔 호스트 1)
유지보수 점검	전체 6 · 지연 1 · 승인대기 1 · 승인 2 · 반려 1
CTI 자산영향	수집 5 · 자산매칭 4 · 영향 자산 3 · 긴급 3
컴플라이언스	KISA 위협 21항목 · 대응률 집계
AI 학습	배포 모델 0 (학습 실행 시 누적)

모니터링

◆ 대시보드

🔍 보안 분석

보안 업무

◇ AI 자산

🕒 취약점 관리

△ 위협 인텔리전스

📄 보안 운영

📋 리포트-컴플라이언스

AI

● AI 어시스턴트

🧠 AI 지식-모델

🛡️ AI 견고성

시스템

📄 로그

⚙️ 설정

대시보드

보안 KPI

📊 보안 KPI 대시보드

자산 취약점 점검-CTI-컴플라이언스-AI 학습 지표를 한곳에 모아 보여줍니다. 매일 스냅샷이 쌓여 추세가 되고, 임원-팀장 보고와 방향성 결정에 씁니다.

📌 자산 위험도

전체 자산

6

고위험

2

중위험

0

저위험

4

🔍 취약점 승인 (finding)

전체 finding

289

미검토

238

승인(확정)

51

반려(오답)

0

🔍 유자보수 점검 거버넌스

전체 점검

6

지연

1

승인 대기

1

승인됨

2

🔍 CTI 위협 · 자산 영향

수집 위험

55

자산 매칭 위험

46

영향받는 자산

5

긴급 매칭

3

🔍 취약점 조치 현황 (빈다운)

열린 취약점

285

실제 악용(KEV)

12

이번 조치율

0%

스캔 호스트

2

Critical

48

High

117

신규

283

✓ 고치됨

1

🔥 시작 가이드 0/12

📌 조치 항목 · SLA

조치 항목

3

기한 초과

1

임박(3일 이)

1

SLA 준수율

67%

✓ 컴플라이언스 · AI 학습

KISA 위험 항목

21

대응 완료

1

대응률

5%

배포된 학습 모델

0

📌 취약점 빈다운 (실제 스캔 이력)

열린 취약점 — 재스캔마다 재구성 (줄수록 좋음)

3 → 285 ▲282



● 열린 취약점 ● 실제 악용(KEV) · 2개 스캔 시점 기준 — 실제 저장된 스캔 이력에서 재구성

📌 추세 · 조치 빈다운 (일일 스냅샷)

열린 취약점 (빈다운 — 줄수록 좋음)

285건

최근 3일

실제 악용(KEV)

12건

최근 3일

SLA 준수율

67%

최근 3일

조치 기한 초과

1건

최근 3일

4.11 임원/팀장 보고서

목적: KPI·점검 거버넌스·자산 상세를 담은 docx 보고서를 자동 생성 + 이메일 발송.
경영진 요약은 로컬 LLM이 작성, 유지보수 거버넌스 섹션(승인/반려 감사 추적) 포함.

모니터링

◆ 대시보드

🔍 보안 분석

보안 업무

◇ AI 자산

🕒 취약점 관리

△ 위협 인텔리전스

🔴 보안 운영

📄 리포트-컴플라이언스

AI

● AI 어시스턴트

🌸 AI 지식-모델

🛡️ AI 견고성

시스템

📄 로그

⚙️ 설정

내부 리포트

컴플라이언스

컴플라이언스

KISA 「AI 보안 위협 대응 매뉴얼」(2026.7) 위협 분류 × 국제 프레임워크(OWASP-NIST-MITRE) 대응 현황

전체 위협
21대응 완료
1부분 대응
0미대응
20대응률
5%

데이터 위협 (3)

▶ D01

불균형 데이터 데이터

OWASP LLM04:2025 Data and Model Poisoning NIST AML013 Data Poisoning MITRE AMLT0020 Poison Training Data

대응 근거-메모 (선택)

미대응

시 초안

▶ D02

부정확한 데이터 데이터

OWASP LLM04:2025 Data and Model Poisoning NIST AML013 Data Poisoning MITRE AMLT0019 Publish Poisoned Datasets AMLT0020 Poison Training Data

대응 근거-메모 (선택)

미대응

시 초안

▶ D03

개인정보 비식별화 미흡 데이터

OWASP LLM02:2025 Sensitive Information Disclosure

대응 근거-메모 (선택)

미대응

시 초안

모델 위협 (8)

▶ M01

학습 데이터 유출 모델 데이터

OWASP LLM02:2025 Sensitive Information Disclosure LLM10:2025 Unbounded Consumption NIST AML032 Reconstruction AML033 Membership Inference MITRE

AMLT0024:002 Extract AI Model

대응 근거-메모 (선택)

미대응

시 초안

▶ M02

벡터 DB-임베딩 유출 데이터

OWASP LLM08:2025 Vector and Embedding Weaknesses NIST AML035 Prompt Extraction AML038 Data Extraction MITRE AMLT0057 LLM Data Leakage

AMLT0085:000 RAG Databases

벡터DB 접근통제 적용

대응 완료

시 초안

시작 가이드 0/12

▶ M03

시스템 프롬프트 유출 프롬프트

OWASP LLM07:2025 System Prompt Leakage NIST AML038 Data Extraction MITRE AMLT0056 Extract LLM System Prompt

대응 근거-메모 (선택)

미대응

시 초안

▶ M04

모델 유출 모델

OWASP LLM10:2023 Model Theft NIST AML031 Model Extraction MITRE AMLT0024:002 Extract AI Model

대응 근거-메모 (선택)

미대응

시 초안

▶ M05

환각 모델 프롬프트

OWASP LLM09:2025 Misinformation MITRE AMLT0062 Discover LLM Hallucinations

대응 근거-메모 (선택)

미대응

시 초안

▶ M06

탈옥 프롬프트

OWASP LLM01:2025 Prompt Injection NIST AML018 Prompt Injection MITRE AMLT0054 LLM Jailbreak

대응 근거-메모 (선택)

미대응

시 초안

▶ M07

부적절한 출력 처리 모델 에이전트 도구

OWASP LLM05:2025 Improper Output Handling NIST AML027 Misaligned Outputs MITRE AMLT0067 LLM Trusted Output Components Manipulation

대응 근거-메모 (선택)

미대응

시 초안

▶ M08

모델 DoS 인프라

OWASP LLM10:2025 Unbounded Consumption NIST AML016 Availability Attacks MITRE AMLT0029 Denial of AI Service

대응 근거-메모 (선택)

미대응

시 초안

에이전트 위협 (4)

▶ A01

부적절한 도구 설계 에이전트 도구

OWASP LLM06:2025 Excessive Agency NIST AML018 Prompt Injection MITRE AMLT0053 AMLT0081 AMLT0086

대응 근거-메모 (선택)

미대응

시 초안

▶ A02

에이전트 하이재킹 프롬프트 에이전트 도구

OWASP LLM01:2025 Prompt Injection LLM06:2025 Excessive Agency NIST AML015 Indirect Prompt Injection MITRE AMLT0051:001 LLM Prompt Injection - Indirect

대응 근거-메모 (선택)

미대응

시 초안

▶ A03

에이전트 DoS 에이전트 도구 인프라

OWASP LLM10:2025 Unbounded Consumption NIST AML01 Availability Violations MITRE AMLT0029 Denial of AI Service AMLT0034 Cost Harvesting

대응 근거-메모 (선택)

미대응

시 초안

▶ A04

에이전트 메모리 오염 에이전트 도구 데이터

OWASP LLM01:2025 Prompt Injection LLM08:2025 Vector and Embedding Weaknesses NIST AML023 Backdoor Poisoning MITRE

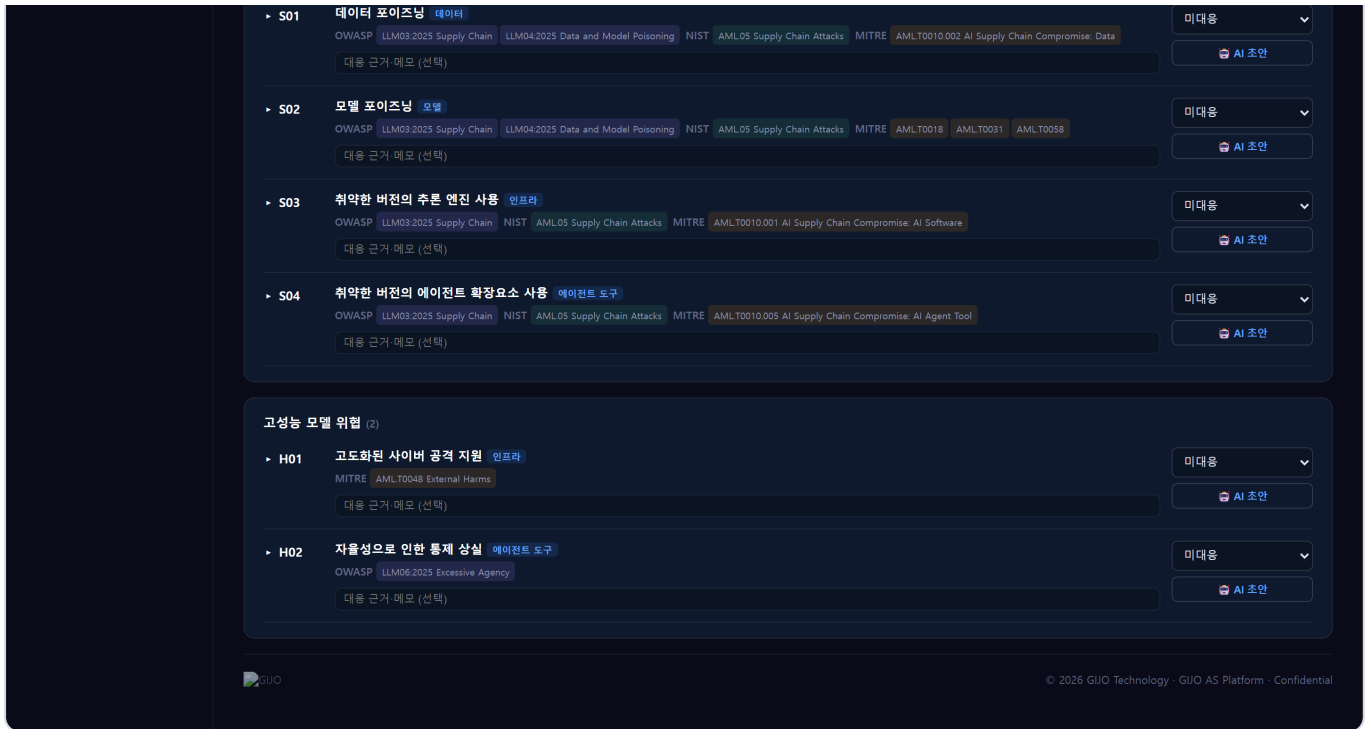
AMLT0080:001 AI Agent Context Poisoning: Memory

대응 근거-메모 (선택)

미대응

시 초안

공급망 위협 (4)



4.12 🛡️ 보안장비 하드닝 점검 · 원격 정기점검 *(신규)*

목적: 방화벽·서버 등 보안장비의 설정 취약점을 국내 **CCE(KISA 주요정보통신기반시설 U-시리즈)+CIS** 기준으로 점검.

- 챗봇 명령("○○ 하드닝 점검해줘") 또는 담당자 PC 터미널(CLI — 허용목록·승인·위험차단)로 즉시 실행 → 분류별 리포트.
- **원격 정기점검:** SSH로 대상을 등록해 스케줄 자동 점검·이력·악화 알림(관제 대시보드). 결과는 통합 관제(보안 분석)의 **4번째** 소스로 상관분석에 합류.

4.13 🚀 MCP 연동 — AI를 외부 도구에 안전하게 연결 *(신규)*

목적: AI 에이전트를 외부 도구·데이터(위협 인텔·스캐너·티켓·SIEM)에 **MCP(Model Context Protocol)**로 표준 연결.

- 온프레미 원칙: **기본 OFF·관리자 게이팅**, 외부로 데이터가 나가는 **원격 서버는 egress 승인**해야 활성화, **에이전트×도구 허용 매트릭스**, 호출 감사.
- 전송 stdio(로컬)/Streamable HTTP(원격). 위협 인텔리전스(CTI) 소스 연결이 대표 사례. *경쟁 SaaS 대비 "데이터 주권을 지키면서 확장"하는 차별점.*

4.14 📄 어디서든 지시 · 작업 기록(감사) *(신규)*

목적: 대시보드가 아닌 **어느 화면에서도** 오른쪽 **작업 화면** 탭으로 지휘 콘솔을 열어 AI에게 자연어로 지시(현재 화면 맥락 자동 전달). 모든 **실행·승인·차단·변경**은 **작업 기록(감사 로그)** 단일 타임라인에 남아 추적됩니다.

5. 한눈에 보는 상관관계 (백데이터 요약)

[샘플 CTI 위험 5건]

[내부 자산 3종]

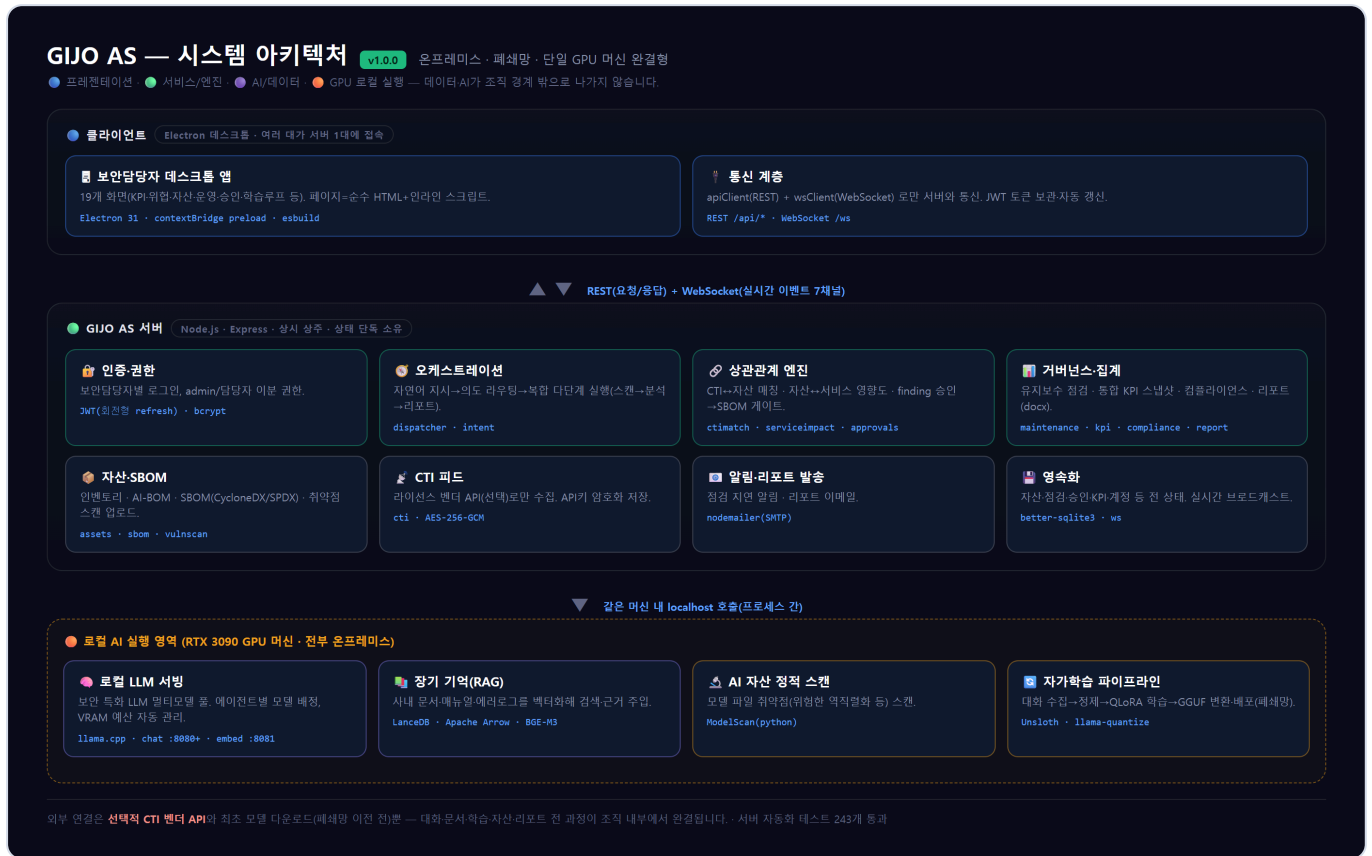
[업무 서비스 3곳]

Qwen2.5 공급망 위험 —매칭(qwen2)—▶ 사내 보안 상담 챗봇 —▶ 임직원 보안 포털 [영향도 높음]
bge-m3 악성 패키지 —매칭(bge)—▶ 사내 보안 상담 챗봇
KoBERT 프롬프트인젝션 —매칭(kobert)—▶ 문서 민감도 분류 AI —▶ 문서관리 시스템 [영향도 높음]
IsolationForest 우회 —매칭(isol...)—▶ 이상행위 탐지 엔진 —▶ SOC 관제 플랫폼 [영향도 높음]
다크웹 계정 유출 —(무관, 제외)

위험이 도착하면 **영향 자산** → **영향 서비스**까지 자동으로 이어져, 담당자는 "무엇부터"만 결정하면 됩니다.

6. 아키텍처 및 적용 기술

6.1 시스템 구성 (한눈에)



3계층 · 단일 GPU 머신 완결형:

[보안담당자 데스크톱(Electron, N대)]

| REST(요청/응답) + WebSocket(실시간 7채널)



[GIJO AS 서버 – Node.js/Express, 상태 단독 소유]

인증 · 오케스트레이션 · 상관관계 엔진 · 거버넌스/집계 · 자산/SBOM · CTI · 알림 · 영속화(SQLite)

| 같은 머신 내 localhost 프로세스 호출



[로컬 AI 실행 영역 – RTX 3090 GPU]

로컬 LLM 서빙(llama.cpp) · RAG 벡터DB(LanceDB) · AI 자산 스캔(ModelScan) · 자가학습(Unsloth)

서버 1대가 **모든 상태를 단독 소유**하고, 여러 데스크톱 클라이언트가 REST/WebSocket으로 접속하는 CS 구조.

서버·AI·데이터가 **한 GPU 머신 안에서 완결**되어 폐쇄망 배포에 적합합니다.

6.2 적용 기술 스택 (레이어별)

레이어	기술	역할
클라이언트	Electron 31 · TypeScript · esbuild	데스크톱 앱. contextBridge preload로 안전한 API 표면만 노출
	apiClient(REST) · wsClient(WebSocket)	서버 통신 · 실시간 이벤트 수신
서버(웹)	Node.js · Express 4 · TypeScript	REST API + 앱 조립. ws 로 WebSocket 브로드캐스트
	JWT(jsonwebtoken) · bcryptjs	담당자별 로그인(회전형 refresh 토큰) · 비밀번호 해시
	better-sqlite3 (SQLite, WAL)	자산·점검·승인·KPI·계정 등 전 상태 영속화
	AES-256-GCM(cryptopack)	CTI/SMTP 비밀키 암호화 저장(평문 저장 안 함)
문서/표준	@cyclonedx/cyclonedx-library	SBOM CycloneDX 1.5 생성
	(직접 생성) SPDX-2.3 JSON	SBOM SPDX 내보내기
	docx	임원/팀장 리포트(.docx) 생성
	nodemailer(SMTP)	리포트·점검 지연 알림 이메일
	simple-git	리포지토리 스캔(자산 자동 등록)
AI/데이터	llama.cpp	로컬 LLM 서빙(채팅 :8080+ 멀티모델 풀, 임베딩 :8081)
	LanceDB · Apache Arrow	장기 기억(RAG) 벡터 저장·검색
	BGE-M3	임베딩 모델(RAG 검색용)
	ModelScan (python)	AI 모델 파일 정적 취약점 스캔
	Unsloth · llama-quantize	QLoRA 파인튜닝 · GGUF 변환·양자화(자가학습)
	pypdf / OWPML	문서(PDF·HWPX·에러로그) 텍스트 추출
프로토콜	MCP(@modelcontextprotocol/sdk)	도구/에이전트 연동 표준

6.3 실시간 처리 — WebSocket 이벤트 채널(7종)

서버가 상태 변화를 모든 접속 클라이언트에 즉시 브로드캐스트합니다(풀링 없음):

collaboration:event (에이전트 협업) · llm:event (추론 실행) · asset:updated (자산 갱신) · finetune:progress · learnloop:progress (학습 진행) · hf-download:progress (모델 다운로드) · log:event (서버 로그)

6.4 핵심 데이터 흐름

- 1. **복합 지시:** 자연어 → 의도 라우팅(로컬 LLM, 규칙 풀백) → 다단계 실행 → 협업 로그 실시간 표출
- 2. **RAG:** 문서 업로드 → 텍스트 추출(python) → 청크·임베딩(BGE-M3) → LanceDB → 채팅 시 근거 주입

3. **자가학습 루프:** 대화 수집(SQLite) → 🍌 정제 → QLoRA 학습(Unsloth) → GGUF 변환(llama.cpp) → 에이전트 배포
4. **상관관계:** CTI 위협 텍스트 ↔ 자산 식별자 토큰 매칭 → 영향 자산 → 서비스 영향도 롤업

6.5 보안·배포 특성 (폐쇄망 설계)

항목	내용
데이터 주권	대화·문서·학습·자산·리포트 전 과정이 조직 내부에서 완결
외부 연결	선택적 CTI 벤더 API + 최초 모델 다운로드(폐쇄망 이전 전)뿐
GPU 조율	학습·병합 시 추론 엔진 자동 정지→재기동(단일 3090 VRAM 충돌 방지)
인증·권한	보안담당자별 로그인(JWT), admin/담당자 이분 권한
비밀정보	API키·SMTP 비밀번호 AES-256-GCM 암호화(평문 저장 안 함)
품질	서버 자동화 테스트 720개 통과 (84 파일), 실기동 엔드투엔드 검증 + 클라 GUI 스모크

6.6 확장·운영

- **모델 자유 교체:** 추천 LLM 가이드에서 보안·학습·RAG·경량 모델을 용도별로 다운로드, 에이전트별 배정
- **자산 자동 유입:** Nessus `.nessus` /CSV/HTML 업로드 · Git 리포지토리 스캔으로 자산 자동 등록
- **보안제품·매뉴얼:** 종류별 제품 등록 + 매뉴얼 일괄 업로드(파일명 자동 분류·제품 자동 등록) → RAG 학습
- **모델 자산 관리:** AI-BOM 5영역(모델·데이터·프롬프트·도구·인프라) + SBOM 표준 내보내기
- **GIJO 합성 모델:** 보안 특화 LLM을 SLERP로 합성·양자화해 온프레미스 배포(gijo-main 오케스트레이터 실증)

7. 스크린샷 목록 (`screenshots/` 폴더)

아래 12장은 **실제 제품 화면**을 실측 서버 응답 데이터로 렌더링한 것입니다(1440×960, 2배 해상도). 모든 화면의 사이드바는 **아이콘 레일 + 서브패널**(관제·모니터링 / 자산·취약점·대응 / AI / 시스템 + 기능 안내·설정)로 구성되며, 관제·모니터링에 🍌 **MCP 연동**이 추가되었습니다(v2.3.0). *일부 신규 화면(MCP·전 페이지 지휘 콘솔)은 캡처 목록에 아직 미포함.*

파일	화면	보이는 실측 데이터
01-보안KPI대시보드.png	보안 KPI	취약점 번다운·KEV·SLA + 자산·점검·CTI·KISA
02-CTI위협-자산매칭.png	위협 인텔리전스	매칭 4건 → 자산 3곳(근거 토큰)
03-AI자산-서비스영향도.png	AI 자산	서비스 3곳 모두 "영향도 높음"
04-운영가이드-점검거버넌스.png	운영 가이드	점검 6건(전 상태)
05-승인워크플로우.png	승인 워크플로우	finding 검토 게이트
06-헤르메스학습루프.png	헤르메스 학습 루프	수집→정제→학습→배포
07-추천LLM가이드.png	추천 LLM 가이드	4카테고리 + 추천 배치
08-에이전트AI.png	에이전트 AI	8종 에이전트 카드
09-컴플라이언스.png	컴플라이언스	KISA 위협 21항목
10-AI-BOM-SBOM.png	AI-BOM	자산별 SBOM 생성/내보내기
11-취약자산관리-생애주기.png	취약 자산관리	Nessus 임포트·Critical 1(Log4Shell)·KEV·심각도 집계
12-보안제품관리-매뉴얼.png	보안제품 관리	종류별 4제품·제품/로그 매뉴얼·점검 연결

재생성: 서버를 `GIJO_SERVER_PORT=4068` 로 기동 후 `node tools/gen-screenshots.mjs` (Windows Edge 사용).

실제 운영 환경 캡처가 필요하면 GIJO AS 데스크톱 앱을 로그인해 각 메뉴에서 촬영하면 됩니다.

*문서 버전: **v2.3.0** · 데이터 기준일: 2026-07-20 · 수치는 실제 서버 구동 결과(자동화 테스트 720개 통과). 스크린샷은 v2.0.0 기준으로, 신규 화면(하드닝·원격점검·MCP·전 페이지 지휘 콘솔) 캡처는 다음 갱신 예정.*